Identity & Federation

© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

IAM – What should you know by now

- Users: long term credentials
- Groups
- Roles: short-term credentials, uses STS
  - EC2 Instance Roles: uses the **EC2 metadata** service. One role at a time per instance
  - Service Roles: API Gateway, CodeDeploy, etc…
  - Cross Account roles
- Policies
  - AWS Managed
  - Customer Managed
  - Inline Policies
- Resource Based Policies (S3 bucket, SQS queue, etc…)

© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

IAM Policies Deep Dive

- Anatomy of a policy: JSON doc with Effect, Action, Resource, Conditions, Policy Variables
- Explicit DENY has precedence over ALLOW
- Best practice: use least privilege for maximum security
  - Access Advisor: See permissions granted and when last accessed
  - Access Analyzer: Analyze resources that are shared with external entity
- Navigate Examples at: https://docs.aws.amazon.com/IAM/latest/UserGuide/access_policies_examples.html

```
{
    "Version": "2012-10-17",
    "Statement": [
        {
            "Effect": "Allow",
            "Action": [
                "ec2:AttachVolume",
                "ec2:DetachVolume"
            ],
            "Resource": "arn:aws:ec2:*:*:instance/*",
            "Condition": {
                "StringEquals": {"ec2:ResourceTag/Department": "Development"}
            }
        },
        {
            "Effect": "Allow",
            "Action": [
                "ec2:AttachVolume",
                "ec2:DetachVolume"
            ],
            "Resource": "arn:aws:ec2:*:*:volume/*",
            "Condition": {
                "StringEquals": {"ec2:ResourceTag/VolumeUser": "${aws:username}"}
            }
        }
    ]
}
```

© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

IAM AWS Managed Policies

AdministratorAccess

```
{
   "Version": "2012-10-17",
   "Statement": [
      {
         "Effect": "Allow",
         "Action": "*",
         "Resource": "*"
      }
   ]
}
```

© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

IAM AWS Managed Policies

PowerUserAccess

```
{
   "Version": "2012-10-17",
   "Statement": [
      {
         "Effect": "Allow",
         "NotAction": [
            "iam:*",
            "organizations:*",
            "account:*"
         ],
         "Resource": "*"
      },…
```

```
      …{
         "Effect": "Allow",
         "Action": [
            "iam:CreateServiceLinkedRole",
            "iam:DeleteServiceLinkedRole",
            "iam:ListRoles",
            "organizations:DescribeOrganization”,
            "account:ListRegions"
         ],
         "Resource": "*"
      }
   ]
}
```

Note how ”NotAction” is used instead of Deny

© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

IAM Policies Conditions

"Condition" : { "{condition-operator}" : { "{condition-key}" : "{condition-value}" }}

Operators:

- String (StringEquals, StringNotEquals, StringLike…)
  - "Condition": {"StringEquals": {"aws:PrincipalTag/job-category": "iamuser-admin"}}
  - "Condition": {"StringLike": {"s3:prefix": ["", "home/", "home/${aws:username}/"]}}
- Numeric (NumericEquals, NumericNotEquals, NumericLessThan…)
- Date (DateEquals, DateNotEquals, DateLessThan…)
- Boolean (Bool):
  - “Condition": {"Bool": {"aws:SecureTransport": "true"}}
  - "Condition": {"Bool": {"aws:MultiFactorAuthPresent": "true"}}
- (Not)IpAddress:
  - "Condition": {"IpAddress": {"aws:SourceIp": "203.0.113.0/24"}}
- ArnEquals, ArnLike
- Null: "Condition":{"Null":{"aws:TokenIssueTime":"true"}}

© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

IAM Policies Variables and Tags

Example: ${aws:username}

- "Resource": ["arn:aws:s3:::mybucket/${aws:username}/*"]

AWS Specific:

- aws:CurrentTime, aws:TokenIssueTime, aws:principaltype, aws:SecureTransport, aws:SourceIp, aws:userid, ec2:SourceInstanceARN

Service Specific:

- s3:prefix, s3:max-keys, s3:x-amz-acl, sns:Endpoint, sns:Protocol…

Tag Based:

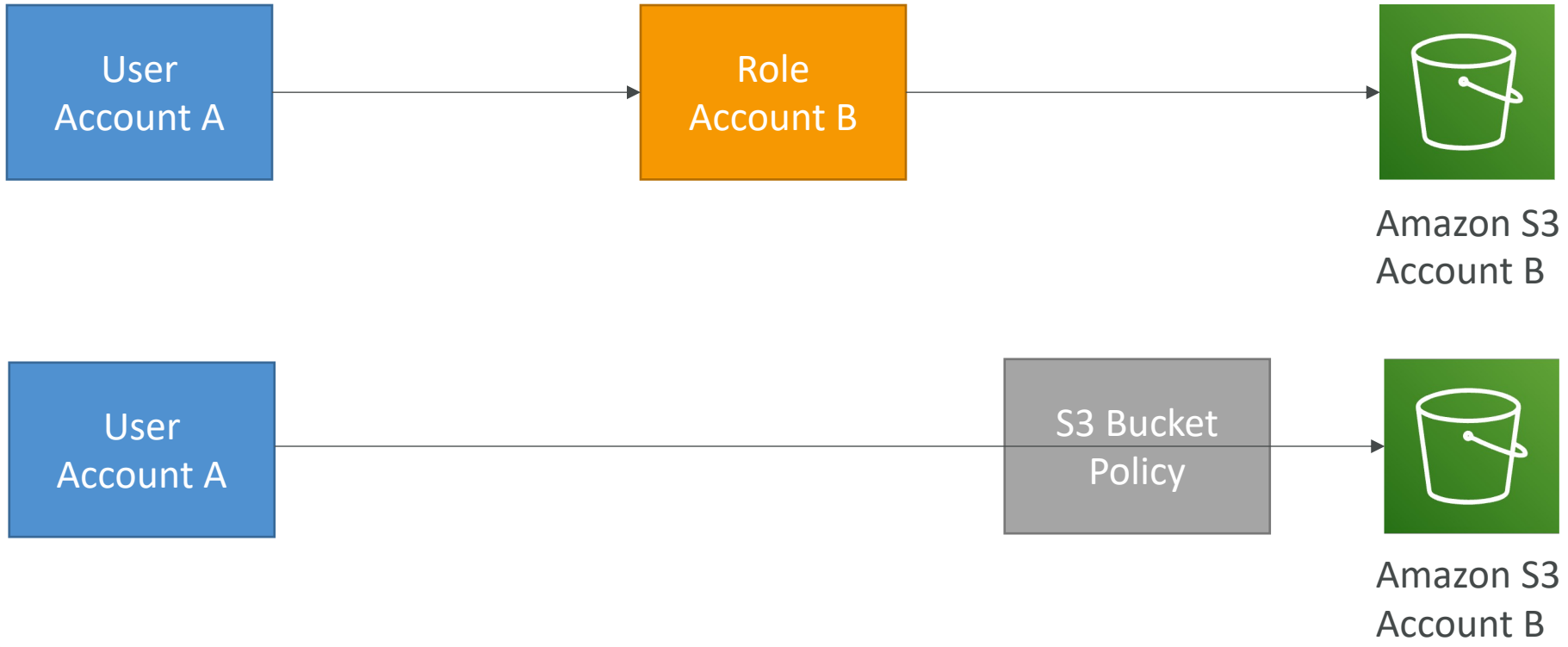
- iam:ResourceTag/key-name, aws:PrincipalTag/key-name…

© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

IAM Roles vs Resource Based Policies

- Attach a policy to a resource (example: S3 bucket policy) versus attaching of a using a role as a proxy



© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

IAM Roles vs Resource Based Policies

- When you assume a role (user, application or service), you give up your original permissions and take the permissions assigned to the role
- When using a resource-based policy, the principal doesn't have to give up any permissions
- Example: User in account A needs to scan a DynamoDB table in Account A and dump it in an S3 bucket in Account B.
- Supported by: Amazon S3 buckets, SNS topics, SQS queues, Lambda functions, ECR, Backup, EFS, Glacier, AWS Artifact, Secrets Manager, ACM, KMS, CloudWatch Logs, API Gateway, EventBridge etc…

© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

IAM Permission Boundaries

- IAM Permission Boundaries are supported for users and roles (not groups)
- Advanced feature to use a managed policy to set the maximum permissions an IAM entity can get.

Example:

```
{
    "Version": "2012-10-17",
    "Statement": [
        {
            "Effect": "Allow",
            "Action": [
                "s3:*",
                "cloudwatch:*",
                "ec2:*"
            ],
            "Resource": "*"
        }
    ]
}
```

IAM Permission Boundary

+

```
{
  "Version": "2012-10-17",
  "Statement": {
    "Effect": "Allow",
    "Action": "iam:CreateUser",
    "Resource": "*"
  }
}
```

IAM Permissions Through IAM Policy

=

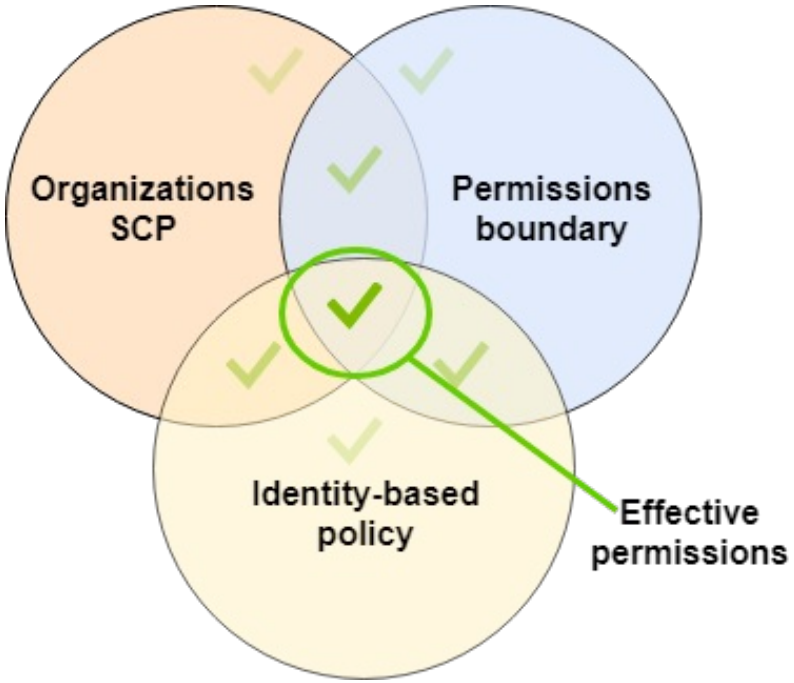
No Permissions

© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

IAM Permission Boundaries

- Can be used in combinations of AWS Organizations SCP



https://docs.aws.amazon.com/IAM/latest/UserGuide/access_policies_boundaries.html

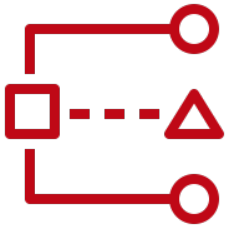
Use cases

- Delegate responsibilities to non administrators within their permission boundaries, for example create new IAM users
- Allow developers to self-assign policies and manage their own permissions, while making sure they can't "escalate" their privileges (= make themselves admin)
- Useful to restrict one specific user (instead of a whole account using Organizations & SCP)

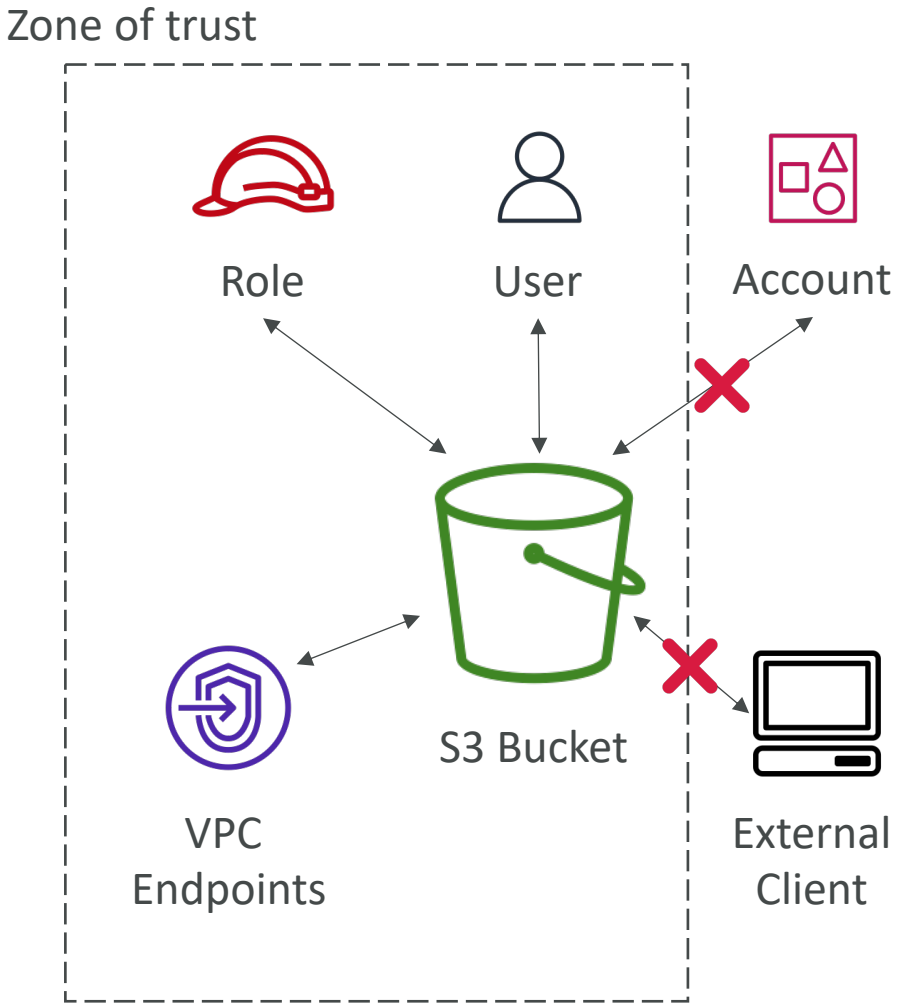
© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

IAM Access Analyzer



- Find out which resources are shared externally
  - S3 Buckets
  - IAM Roles
  - KMS Keys
  - Lambda Functions and Layers
  - SQS queues
  - Secrets Manager Secrets
- Define **Zone of Trust** = AWS Account or AWS Organization
- Access outside zone of trusts => findings



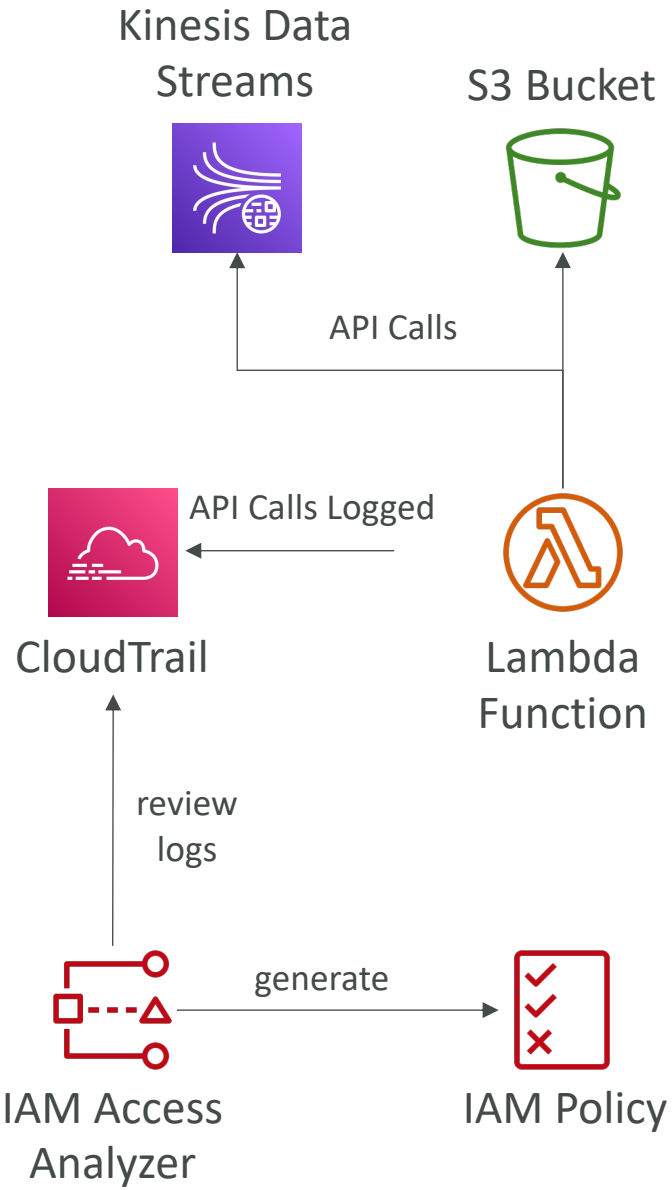
© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

IAM Access Analyzer

- IAM Access Analyzer Policy Validation
  - Validates your policy against IAM policy grammar and best practices
  - General warnings, security warnings, errors, suggestions
  - Provides actionable recommendations

- IAM Access Analyzer Policy Generation
  - Generates IAM policy based on access activity
  - CloudTrail logs is reviewed to generate the policy with the **fine-grained permissions and the appropriate Actions and Services**
  - Reviews CloudTrail logs for up to 90 days

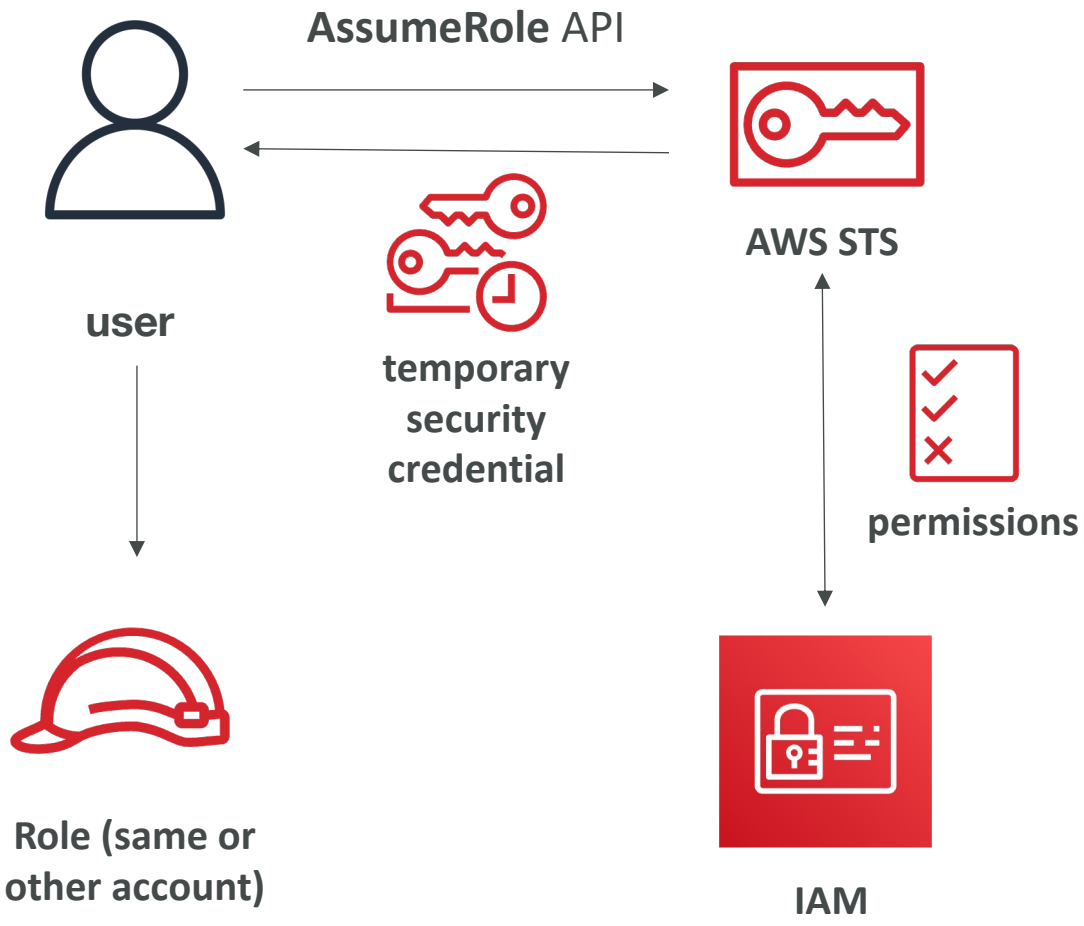


© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

Using STS to Assume a Role

- Define an IAM Role within your account or cross-account
- Define which principals can access this IAM Role
- Use AWS STS (Security Token Service) to retrieve credentials and impersonate the IAM Role you have access to (**AssumeRole API**)
- Temporary credentials can be valid between 15 minutes to 12 hour



© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

Assuming a Role with STS

- Provide access for an IAM user in one AWS account that you own to access resources in another account that you own
- Provide access to IAM users in AWS accounts owned by third parties
- Provide access for services offered by AWS to AWS resources
- Provide access for externally authenticated users (identity federation)

- Ability to revoke active sessions and credentials for a role (by adding a policy using a time statement – AWSRevokeOlderSessions)

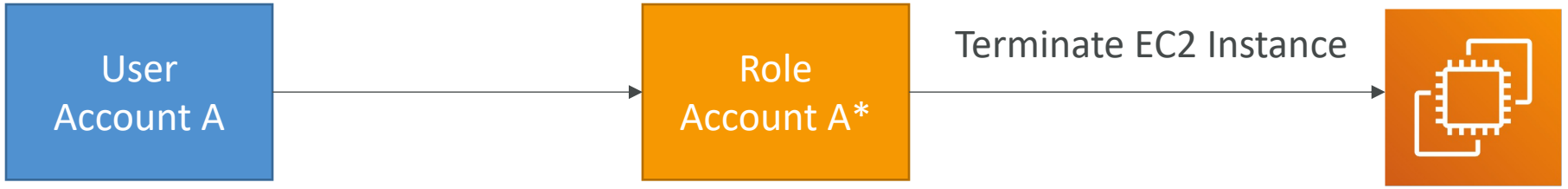
When you assume a role (user, application or service), you give up your original permissions and take the permissions assigned to the role

© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

Providing Access to an IAM User in Your or Another AWS Account That You Own

- You can grant your IAM users permission to switch to roles within your AWS account or to roles defined in other AWS accounts **that you own**.

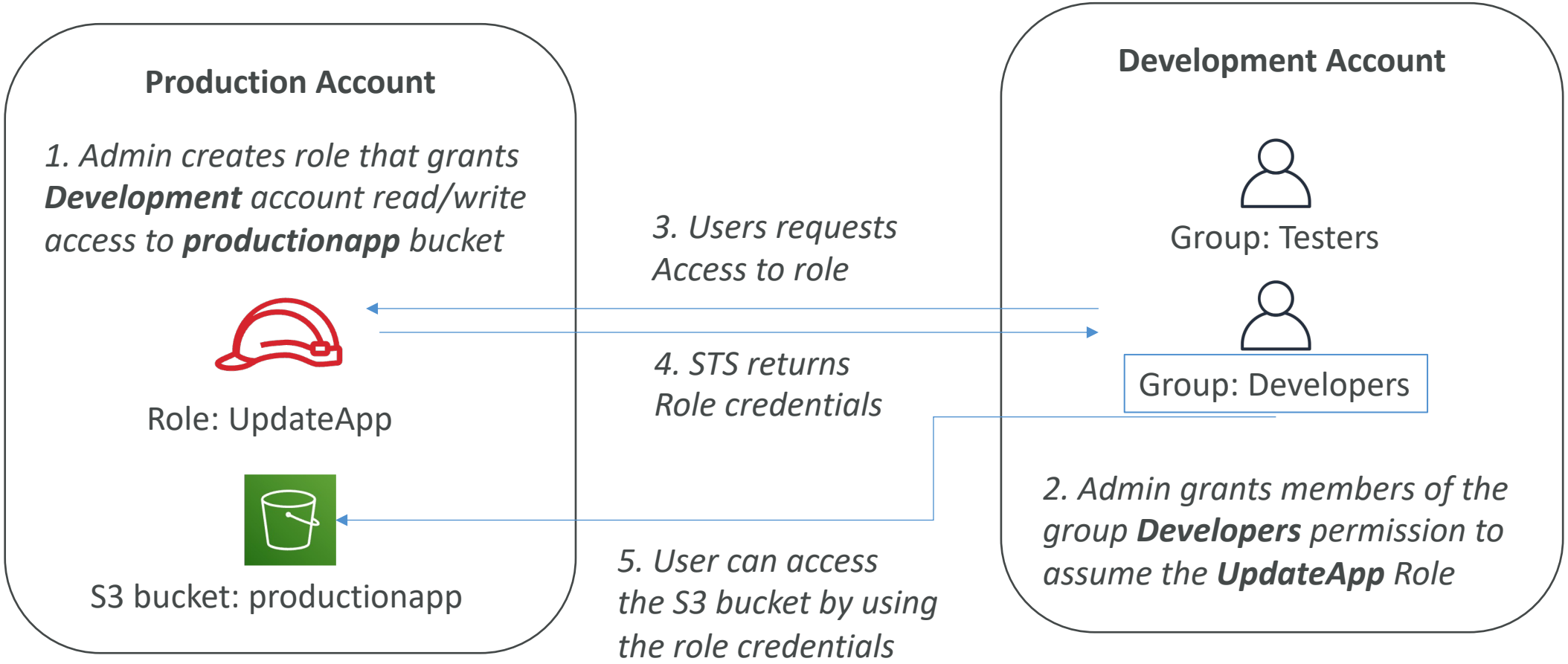


- Benefits:
  - You must explicitly grant your users permission to assume the role.
  - Your users must actively switch to the role using the AWS Management Console or assume the role using the AWS CLI or AWS API
  - **You can add multi-factor authentication (MFA) protection to the role** so that only users who sign in with an MFA device can assume the role
  - Least privilege + auditing using CloudTrail

© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

Cross account access with STS



© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

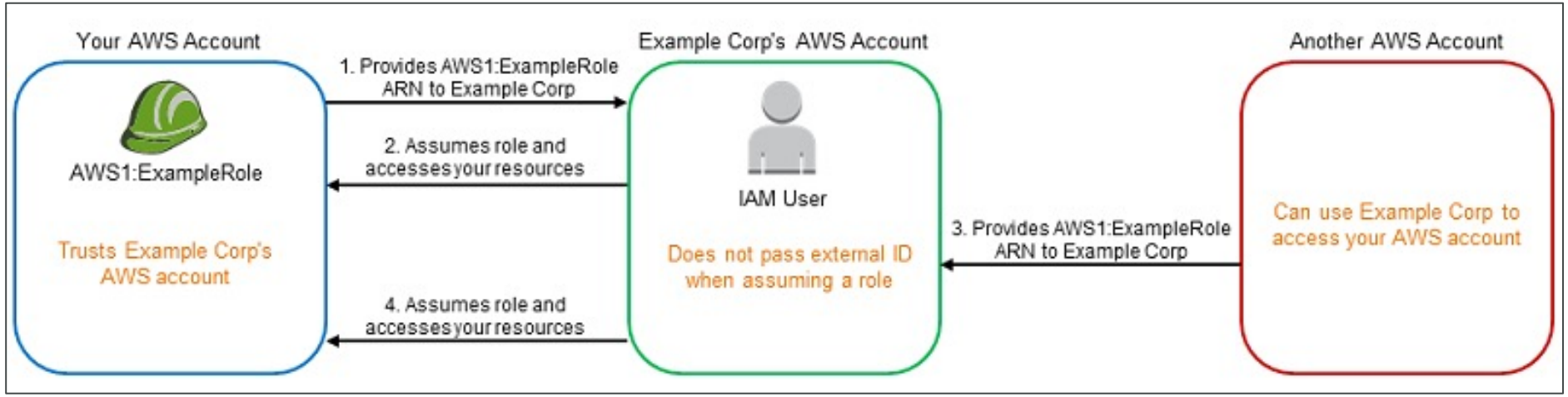
Providing Access to AWS Accounts Owned by Third Parties

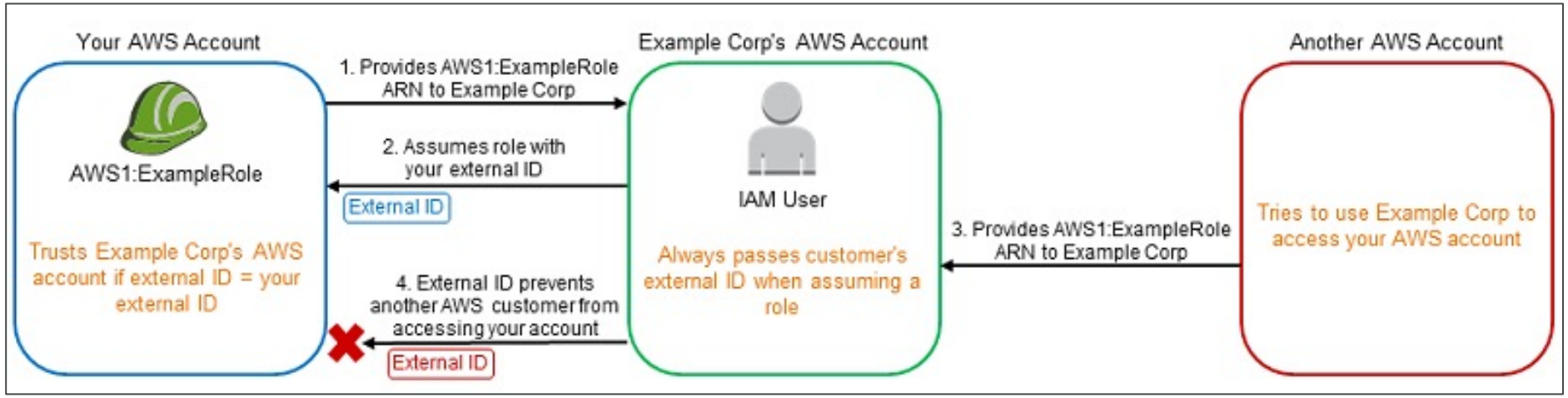
- Zone of trust = accounts, organizations that you own
- Outside Zone of Trust = 3rd parties
- Use IAM Access Analyzer to find out which resources are exposed
- For granting access to a 3rd party:
  - The 3rd party AWS account ID
  - **An External ID** (secret between you and the 3rd party)
    - To uniquely associate with the role between you and 3rd party
    - Must be provided when defining the trust and when assuming the role
    - Must be chosen by the 3rd party
  - Define permissions in the IAM policy

© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

The confused deputy



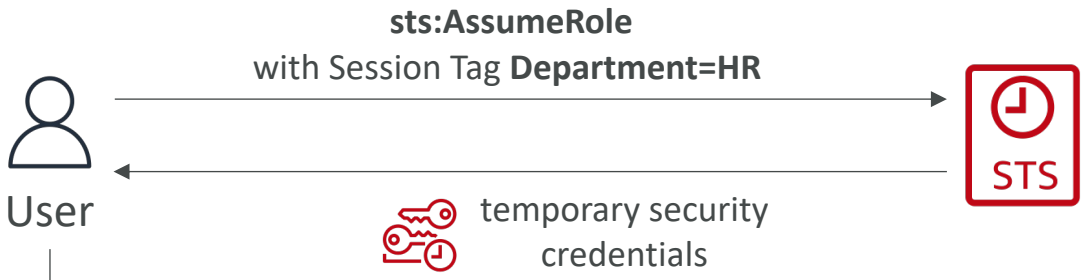


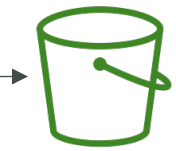
© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

Session Tags in STS

- Tags that you pass when you assume an IAM Role or federate user in STS
- aws:PrincipalTag Condition
  - Compares the tags attached to the principal making the request with the tag you specified in the policy
  - Example: allow a principal to pass session tags only if the principal making the request has the specified tags





S3 Bucket
(hr-docs)

```
{
    "Version": "2012-10-17",
    "Statement": [
      {
        "Effect": "Allow",
        "Action": "s3:GetObject",
        "Resource": "arn:aws:s3:::hr-docs/*",
        "Condition": {
          "StringEquals": {
            "aws:PrincipalTag/Department": "HR"
          }
        }
      }
    ]
}
```

© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

STS Important APIs

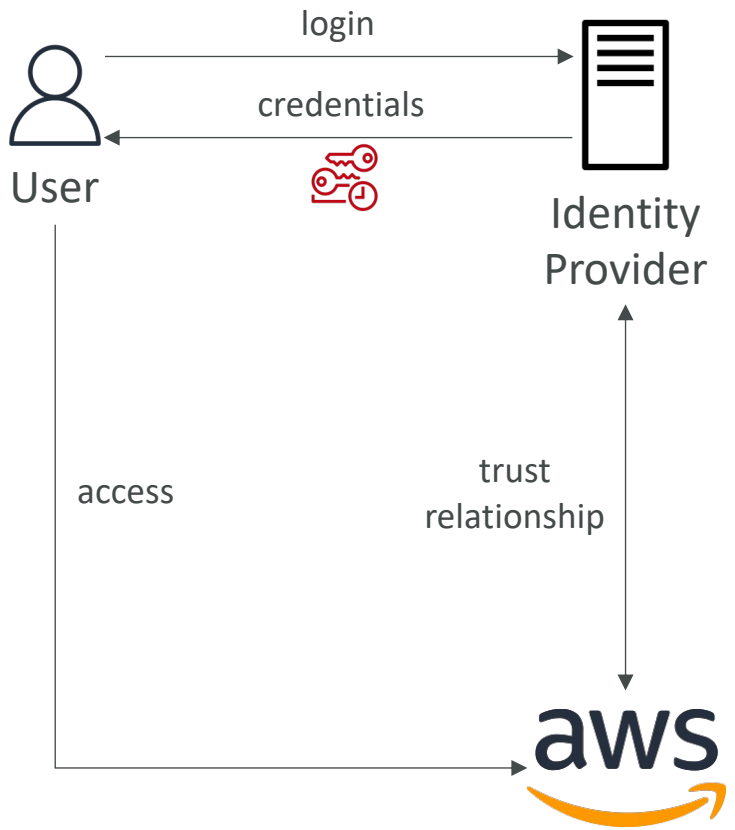
- **AssumeRole**: access a role within your account or cross-account
- **AssumeRoleWithSAML**: return credentials for users logged with SAML
- **AssumeRoleWithWebIdentity**: return creds for users logged with an IdP
  - Example providers include Amazon Cognito, Login with Amazon, Facebook, Google, or any OpenID Connect-compatible identity provider
  - **AWS recommends using Cognito instead**
- **GetSessionToken**: for MFA, from a user or AWS account root user
- **GetFederationToken**: obtain temporary creds for a federated user, usually a proxy app that will give the creds to a distributed app inside a corporate network

© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

Identity Federation in AWS

- Give users outside of AWS permissions to access AWS resources in your account
- **You don't need to create IAM Users (user management is outside AWS)**
- Use cases:
  - A corporate has its own identity system (e.g., Active Directory)
  - Web/Mobile application that needs access to AWS resources
- Identity Federation can have many flavors:
  - SAML 2.0
  - Custom Identity Broker
  - Web Identity Federation With(out) Amazon Cognito
  - IAM Identity Center



© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

SAML 2.0 Federation

- Security Assertion Markup Language 2.0 (SAML 2.0)
- Open standard used by many identity providers (e.g., ADFS)
  - Supports integration with Microsoft Active Directory Federations Services (ADFS)
  - Or any SAML 2.0–compatible IdPs with AWS
- Access to AWS Console, AWS CLI, or AWS API using temporary credentials
  - No need to create IAM Users for each of your employees
  - Need to setup a trust between AWS IAM and SAML 2.0 Identity Provider (both ways)

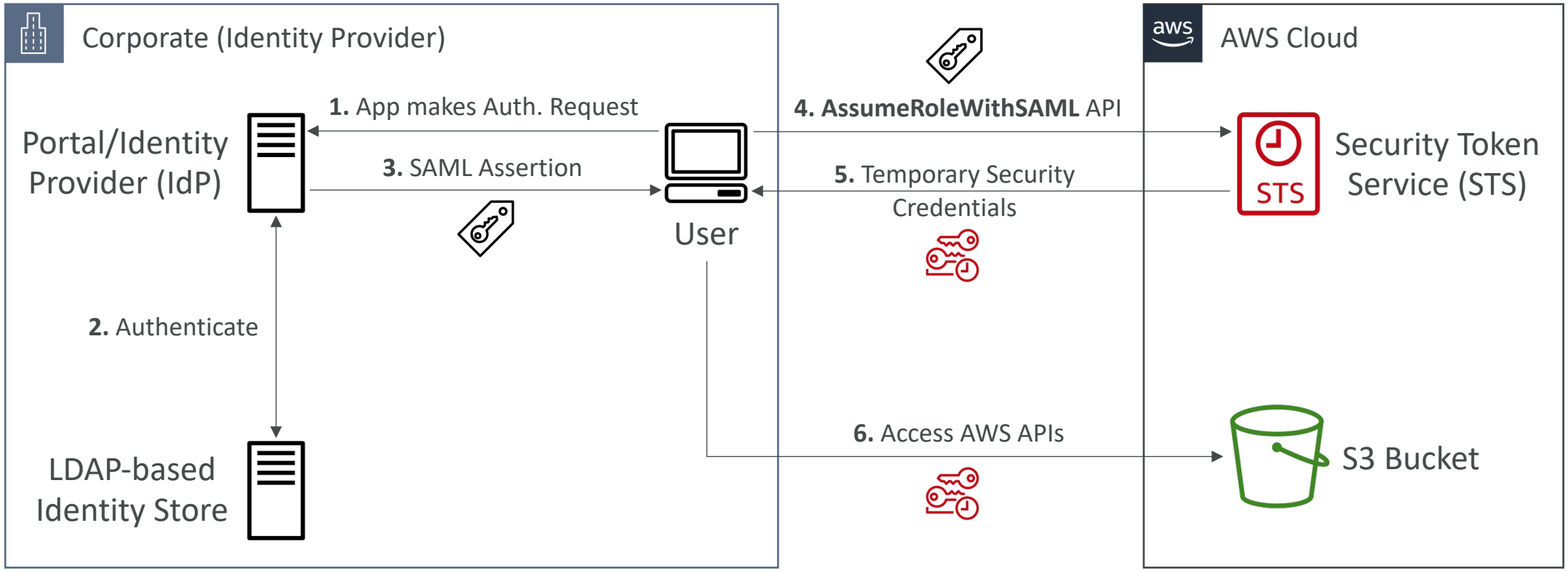
- Under-the-hood: Uses the STS API **AssumeRoleWithSAML**

- SAML 2.0 Federation is the "old way", **IAM Identity Center** Federation is the new managed and simpler way
  - https://docs.aws.amazon.com/singlesignon/latest/userguide/what-is.html

© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

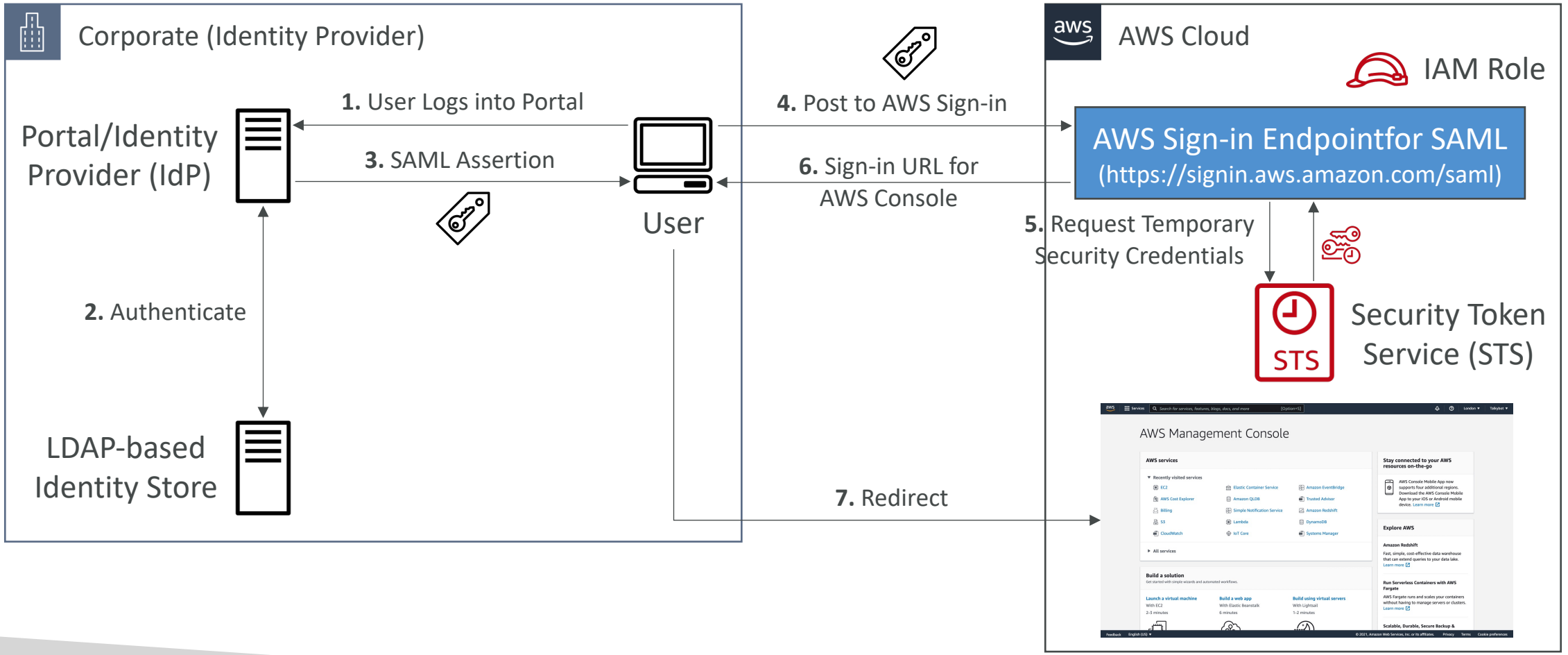
SAML 2.0 Federation – AWS API Access



© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

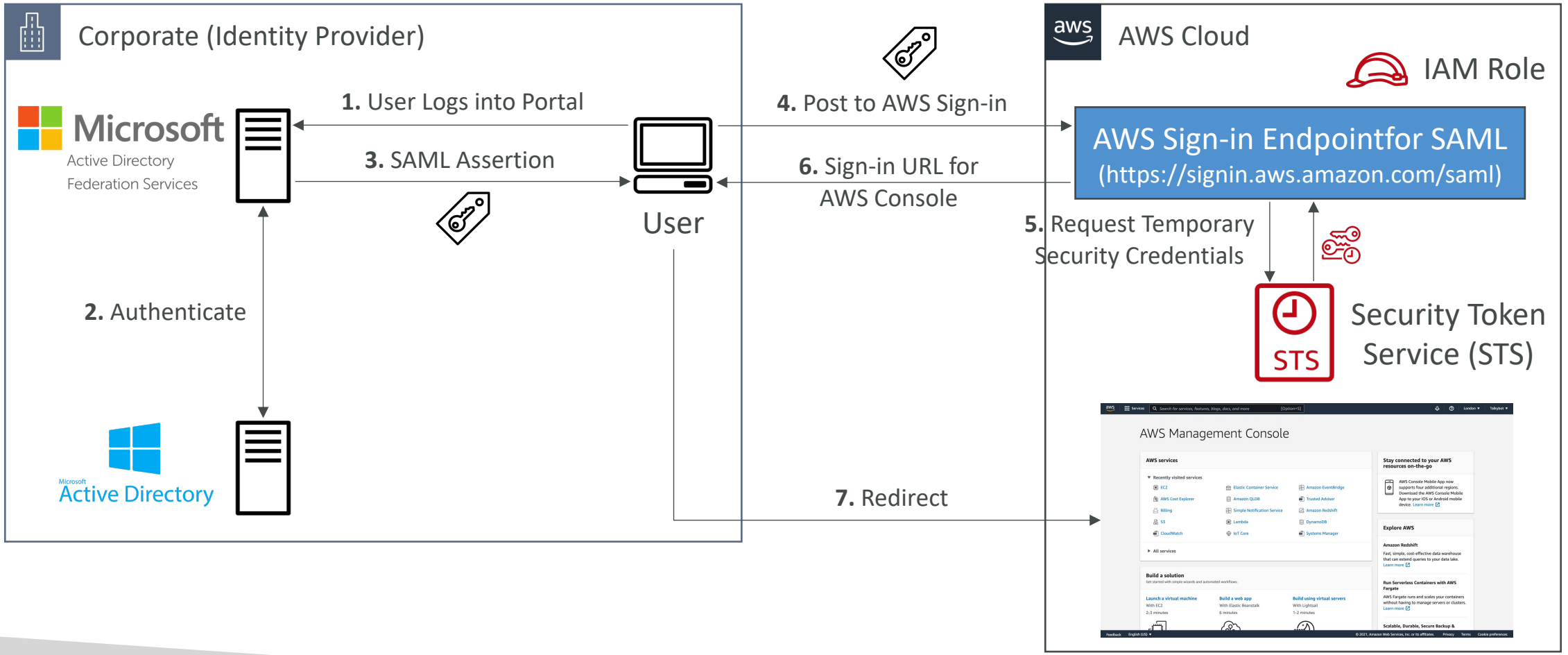
SAML 2.0 Federation – AWS Console Access



© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

SAML 2.0 Federation – Active Directory FS (ADFS)

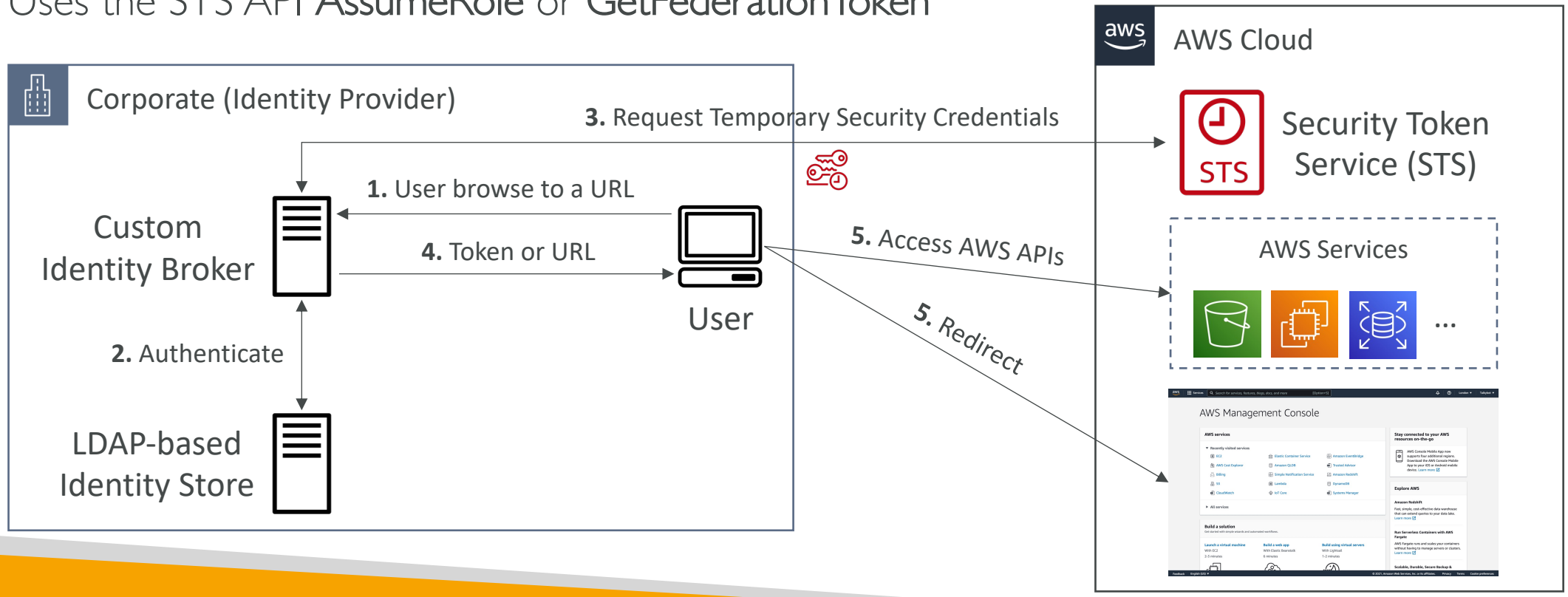


© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

Custom Identity Broker Application

- Use only if Identity Provider is **NOT** compatible with SAML 2.0
- The Identity Broker Authenticates users & requests temporary credentials from AWS
- **The Identity Broker must determine the appropriate IAM Role**
- Uses the STS API **AssumeRole** or **GetFederationToken**

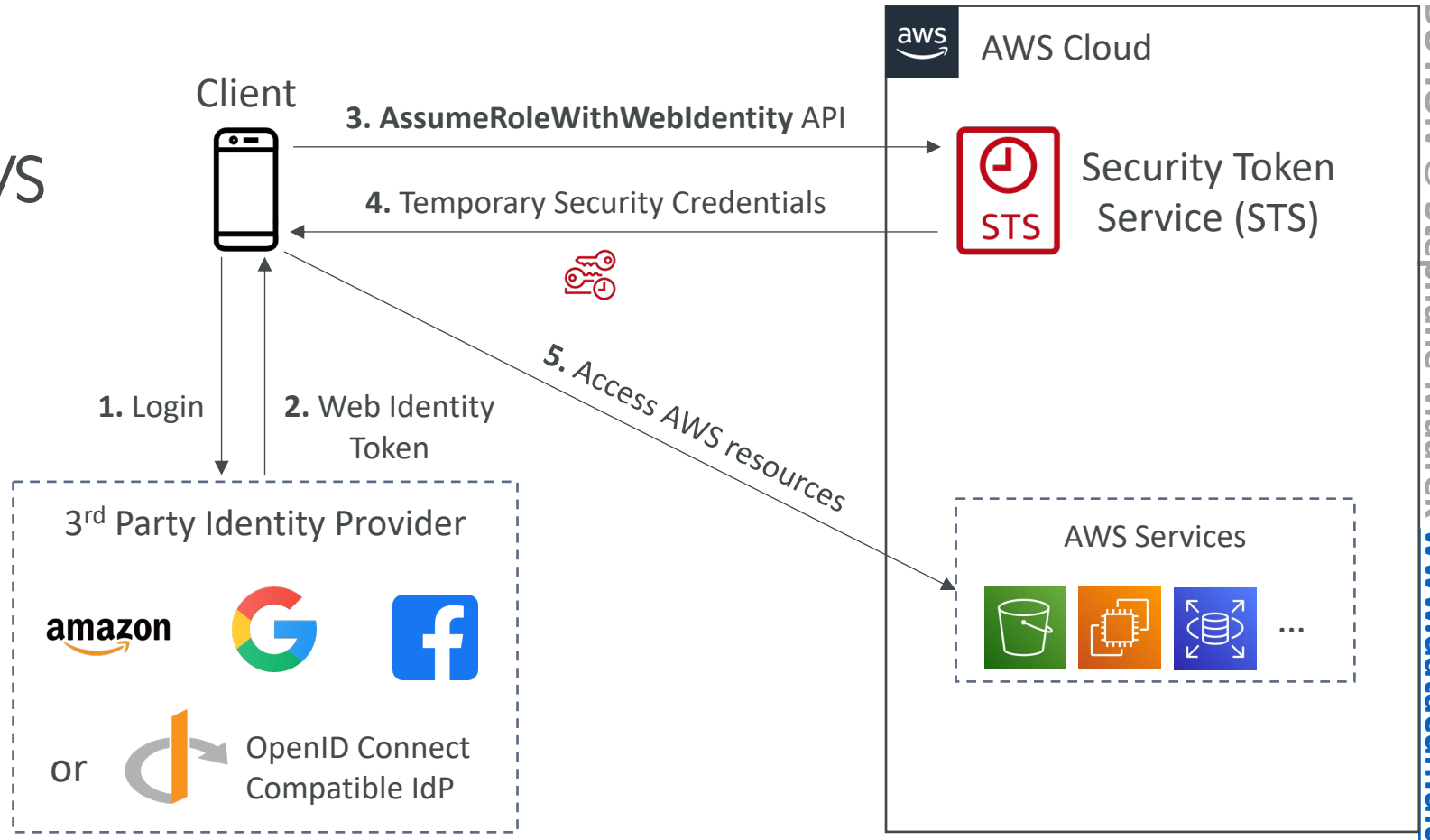


© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

Web Identity Federation – Without Cognito

- Not recommended by AWS – use Cognito instead

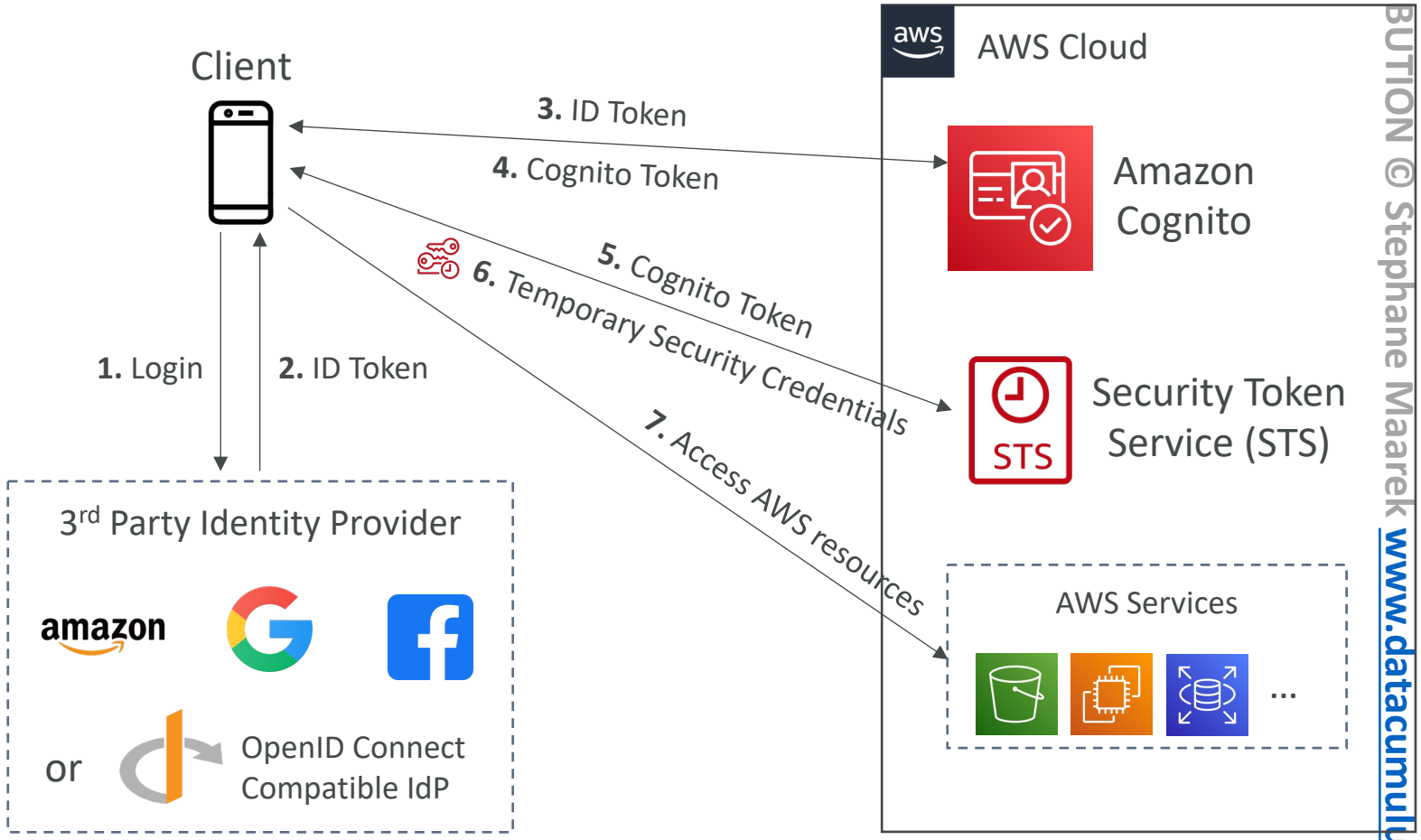


NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

© Stephane Maarek

Web Identity Federation – With Cognito

- Preferred over for Web Identity Federation
  - Create IAM Roles using Cognito with the least privilege needed
  - Build trust between the OIDC IdP and AWS
- Cognito benefits:
  - Supports anonymous users
  - Supports MFA
  - Data Synchronization
- Cognito replaces a Token Vending Machine (TVM)



NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

© Stephane Maarek

Web Identity Federation – IAM Policy

- After being authenticated with Web Identity Federation, you can identify the user with an IAM policy variable

- Examples:
  - cognito-identity.amazonaws.com:sub
  - www.amazon.com:user_id
  - graph.facebook.com:id
  - accounts.google.com:sub

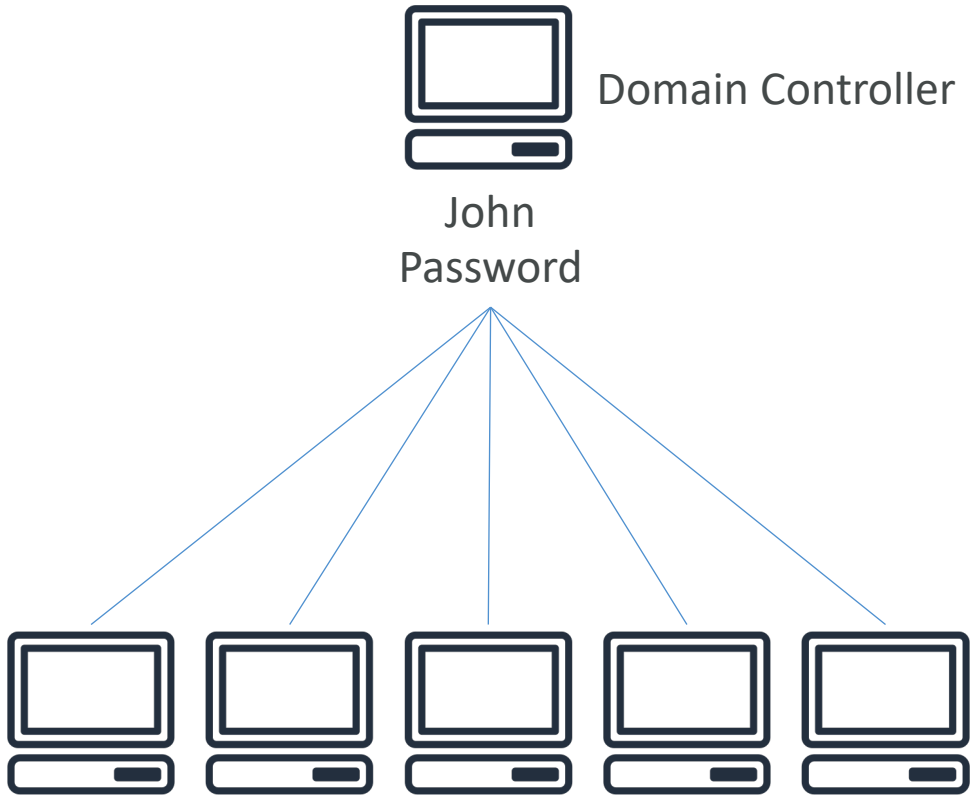
```
{
    "Version": "2012-10-17",
    "Statement": [
        {
            "Effect": "Allow",
            "Action": "s3:ListBucket",
            "Resource": "arn:aws:s3:::myBucket",
            "Condition": {
                "StringLike": {
                    "s3:prefix": "Amazon/mynumbersgame/${www.amazon.com:user_id}/*"
                }
            }
        }, {
            "Effect": "Allow",
            "Action": ["s3:GetObject", "s3:PutObject", "s3:DeleteObject"],
            "Resource": [
                "arn:aws:s3:::myBucket/amazon/mynumbersgame/${www.amazon.com:user_id}",
                "arn:aws:s3:::myBucket/amazon/mynumbersgame/${www.amazon.com:user_id}/*"
            ]
        }
    ]
}
```

© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

What is Microsoft Active Directory (AD)?

- Found on any Windows Server with AD Domain Services
- Database of **objects**: User Accounts, Computers, Printers, File Shares, Security Groups
- Centralized security management, create account, assign permissions
- Objects are organized in **trees**
- A group of trees is a **forest**

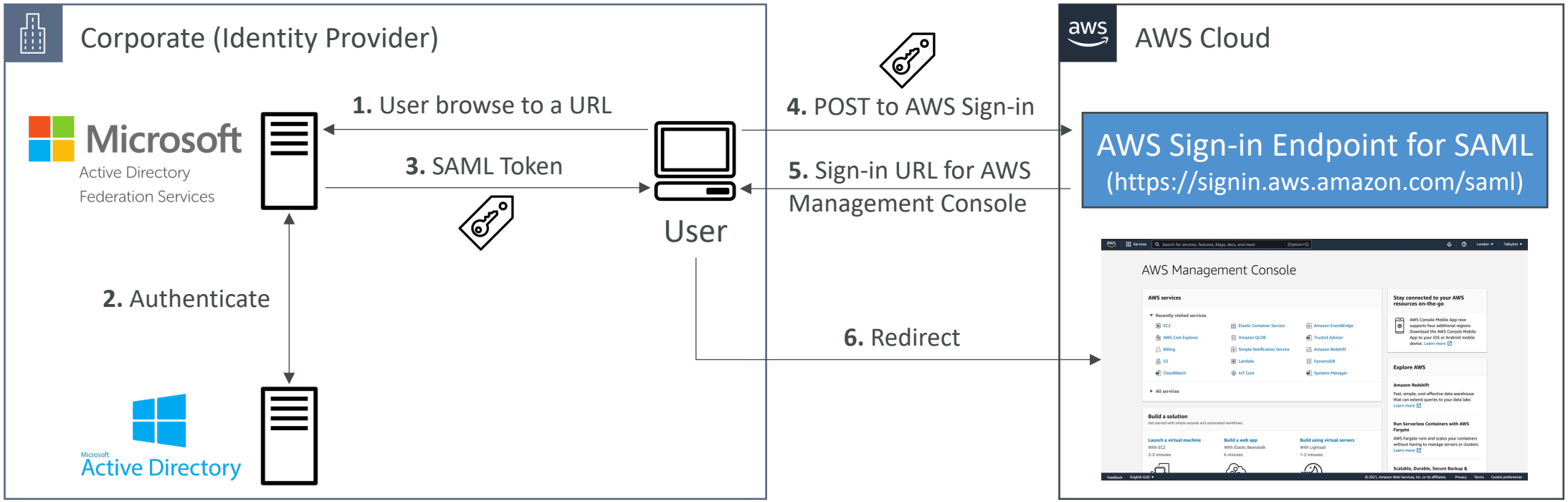


© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

What is ADFS (AD Federation Services)?

- ADFS provides Single Sign-On across applications
- SAML across 3rd party: AWS Console, Dropbox, Office365, etc…

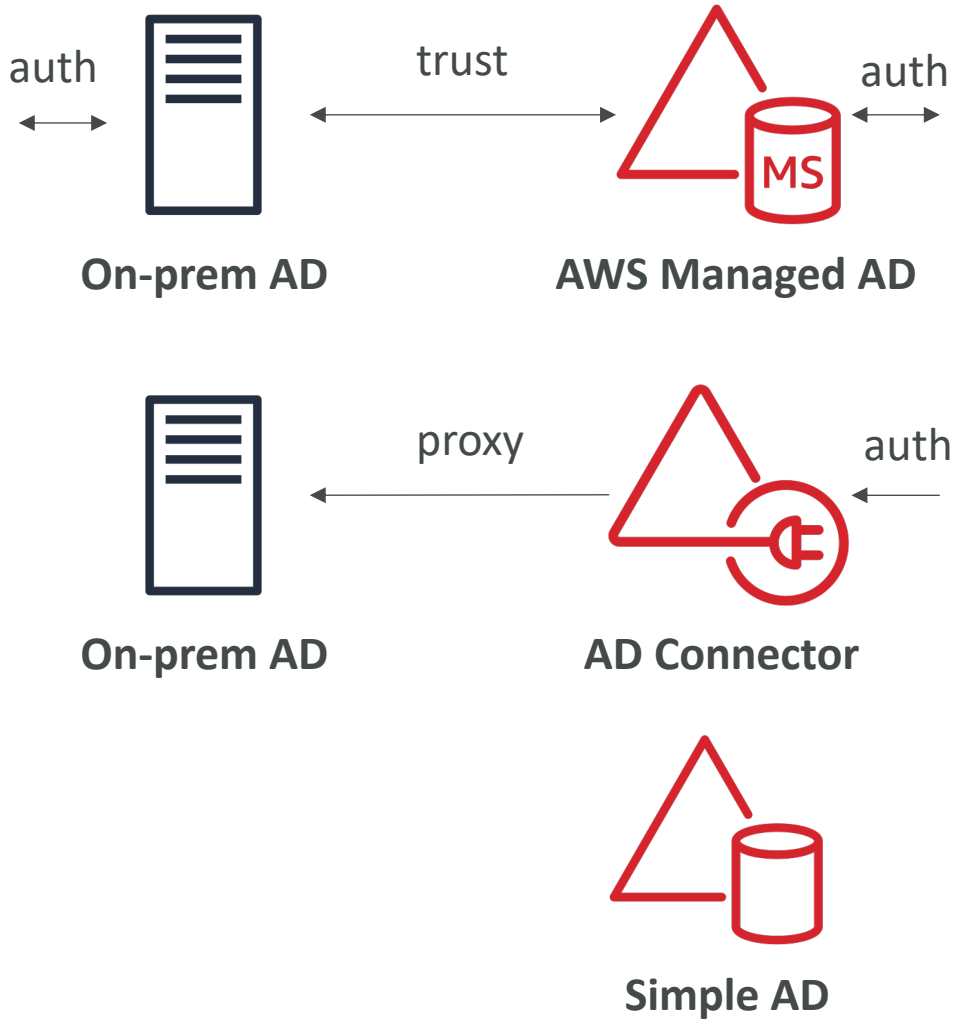


© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

AWS Directory Services

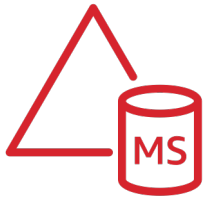
- AWS Managed Microsoft AD
  - Create your own AD in AWS, manage users locally, supports MFA
  - Establish "trust" connections with your on-premises AD
- AD Connector
  - Directory Gateway (proxy) to redirect to on-premises AD, supports MFA
  - Users are managed on the on-premises AD
- Simple AD
  - AD-compatible managed directory on AWS
  - Cannot be joined with on-premises AD



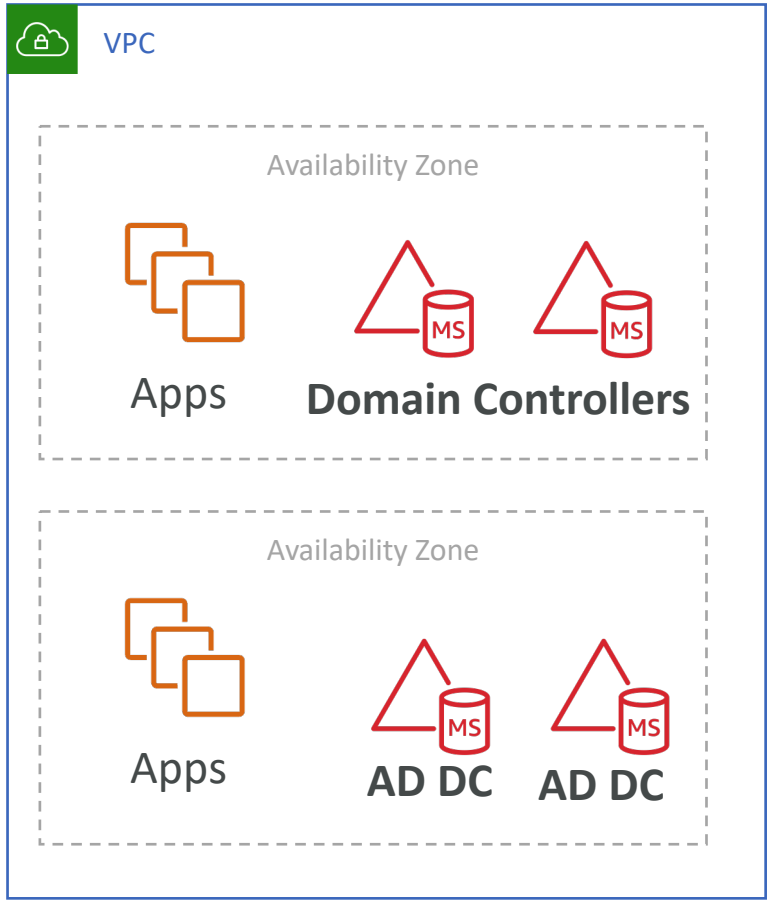
© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

AWS Directory Services
AWS Managed Microsoft AD



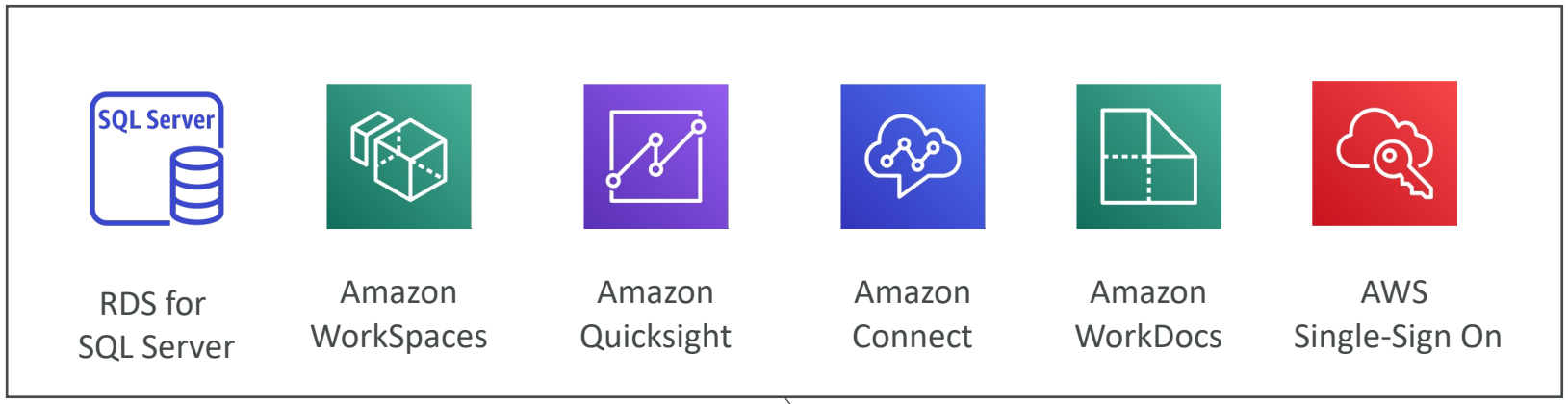
- Managed Service: Microsoft AD in your AWS VPC
- EC2 Windows Instances:
  - EC2 Windows instances can join the domain and run traditional AD applications (sharepoint, etc)
  - Seamlessly Domain Join Amazon EC2 Instances from Multiple Accounts & VPCs
- Integrations:
  - RDS for SQL Server, AWS Workspaces, Quicksight…
  - AWS SSO to provide access to 3rd party applications
- Standalone repository in AWS or joined to on-premises AD
- Multi AZ deployment of AD in 2 AZ, # of DC (Domain Controllers) can be increased for scaling
- Automated backups
- Automated Multi-Region replication of your directory



© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

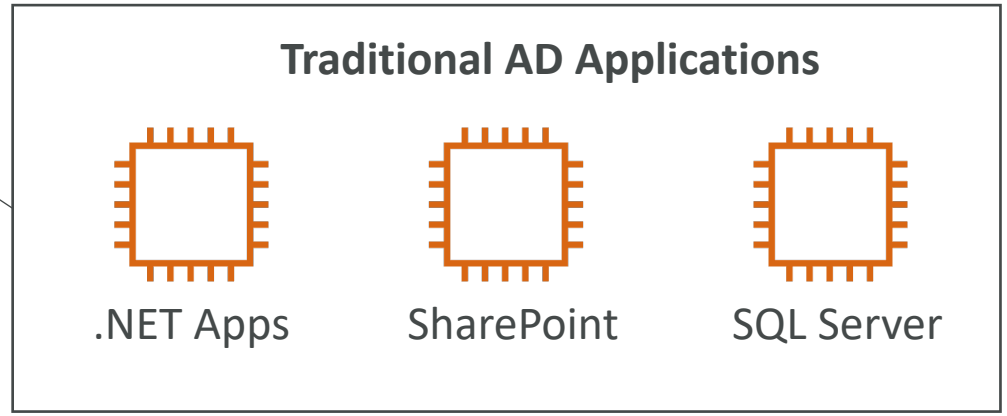
AWS Microsoft Managed AD - Integrations









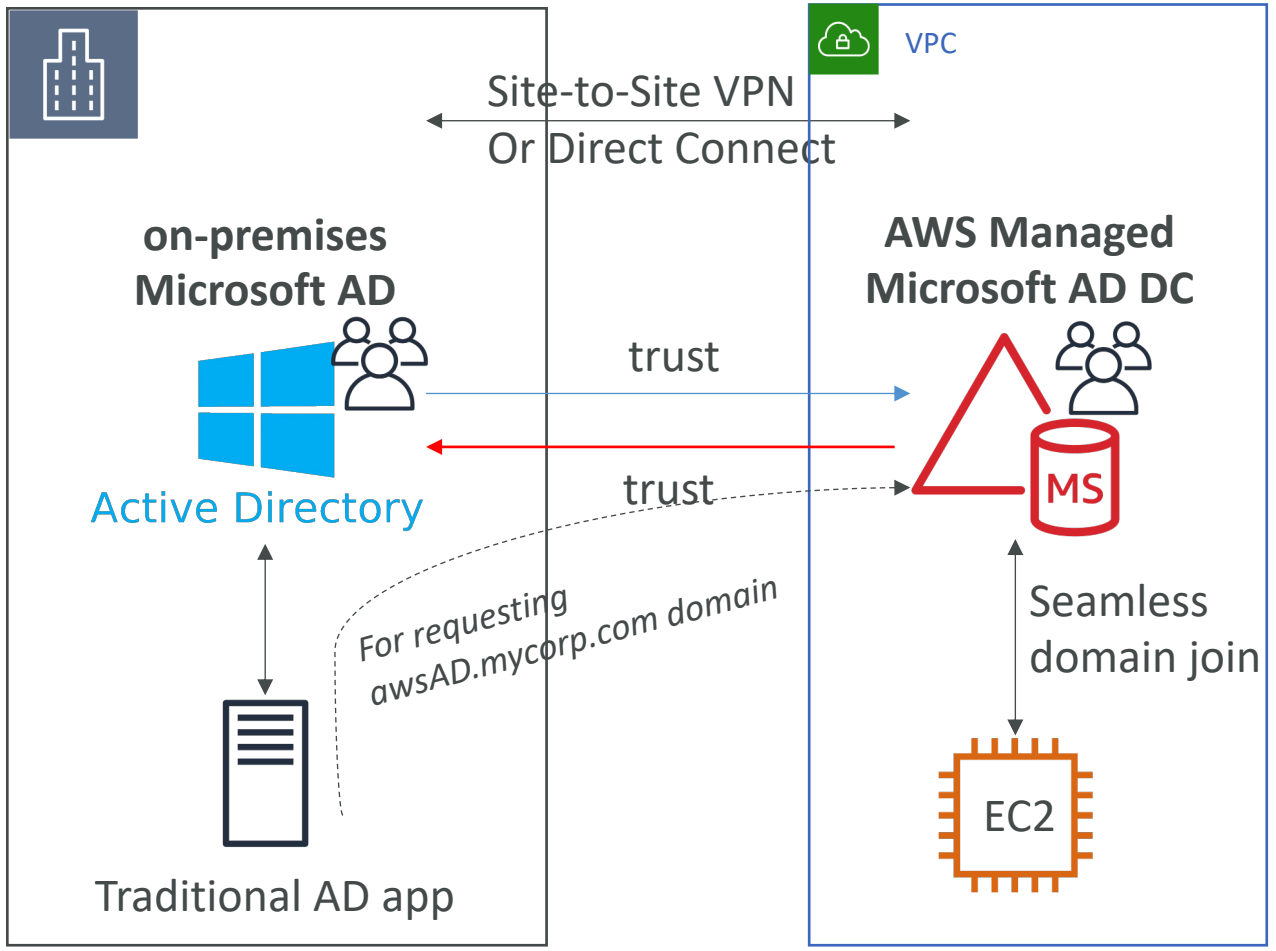


© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

Connect to on-premises AD

- Ability to connect your on-premises Active Directory to AWS Managed Microsoft AD
- Must establish a Direct Connect (DX) or VPN connection
- Can setup three kinds of forest trust:
  - **One-way trust:** AWS => on-premises
  - **One-way trust:** on-premises => AWS
  - **Two-way forest trust:** AWS ⇔ on-premises
- Forest trust is different than synchronization

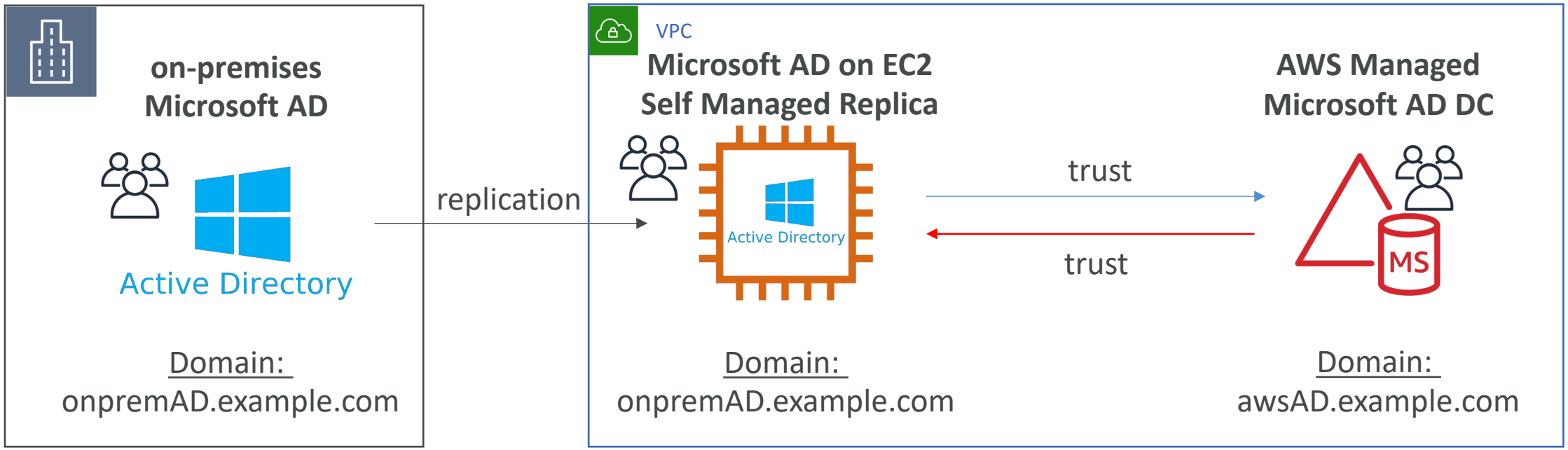


© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

Solution Architecture: Active Directory Replication

- You may want to create a replica of your AD on EC2 in the cloud to minimize latency of in case DX or VPN goes down
- Establish trust between the AWS Managed Microsoft AD and EC2

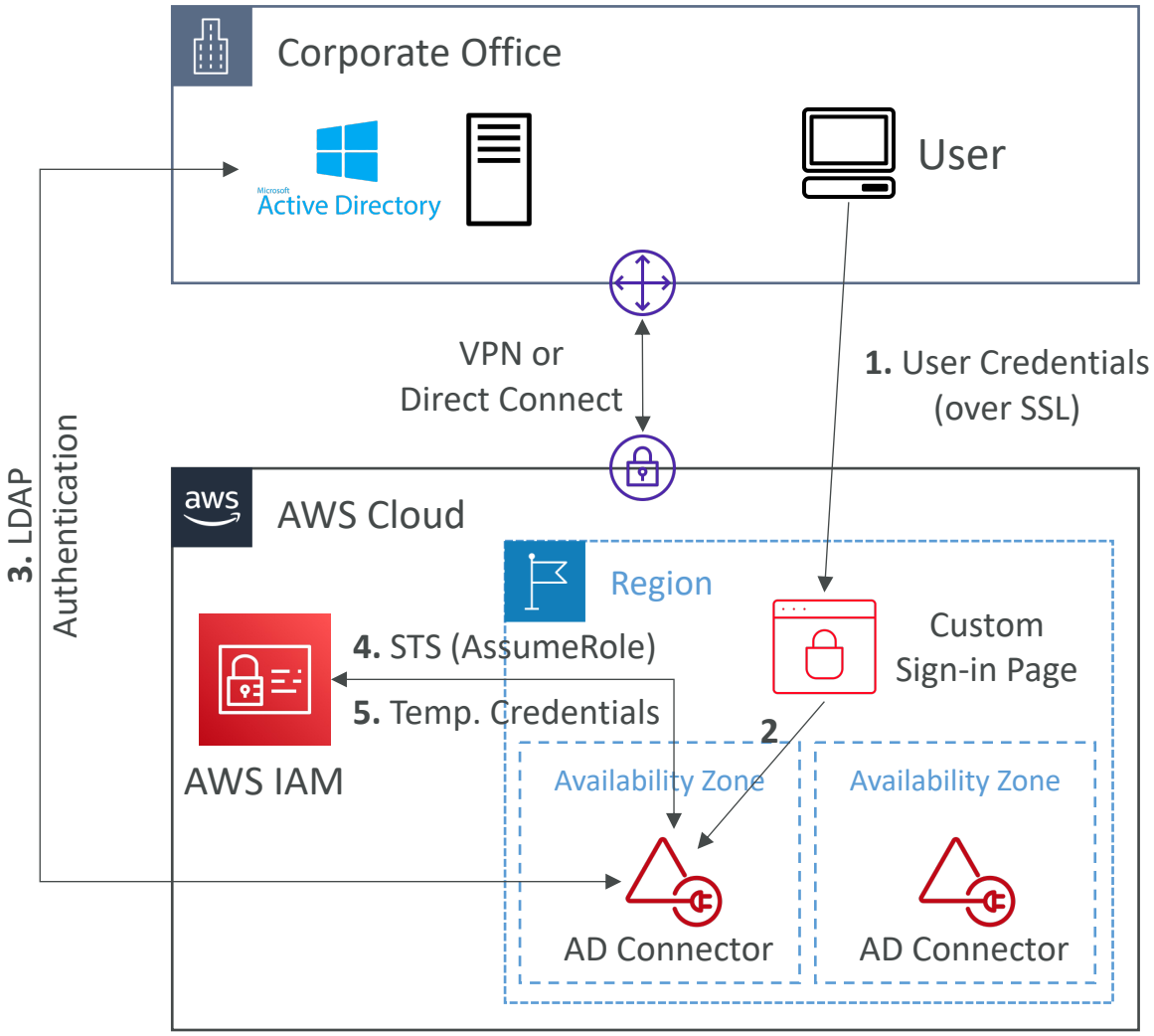


© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

AWS Directory Services
AD Connector

- **AD Connector** is a directory gateway to redirect directory requests to your on-premises Microsoft Active Directory
- No caching capability
- Manage users solely on-premises, no possibility of setting up a trust
- VPN or Direct Connect
- Doesn't work with SQL Server, doesn't do seamless joining, can't share directory



NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

© Stephane Maarek

AWS Directory Services
Simple AD

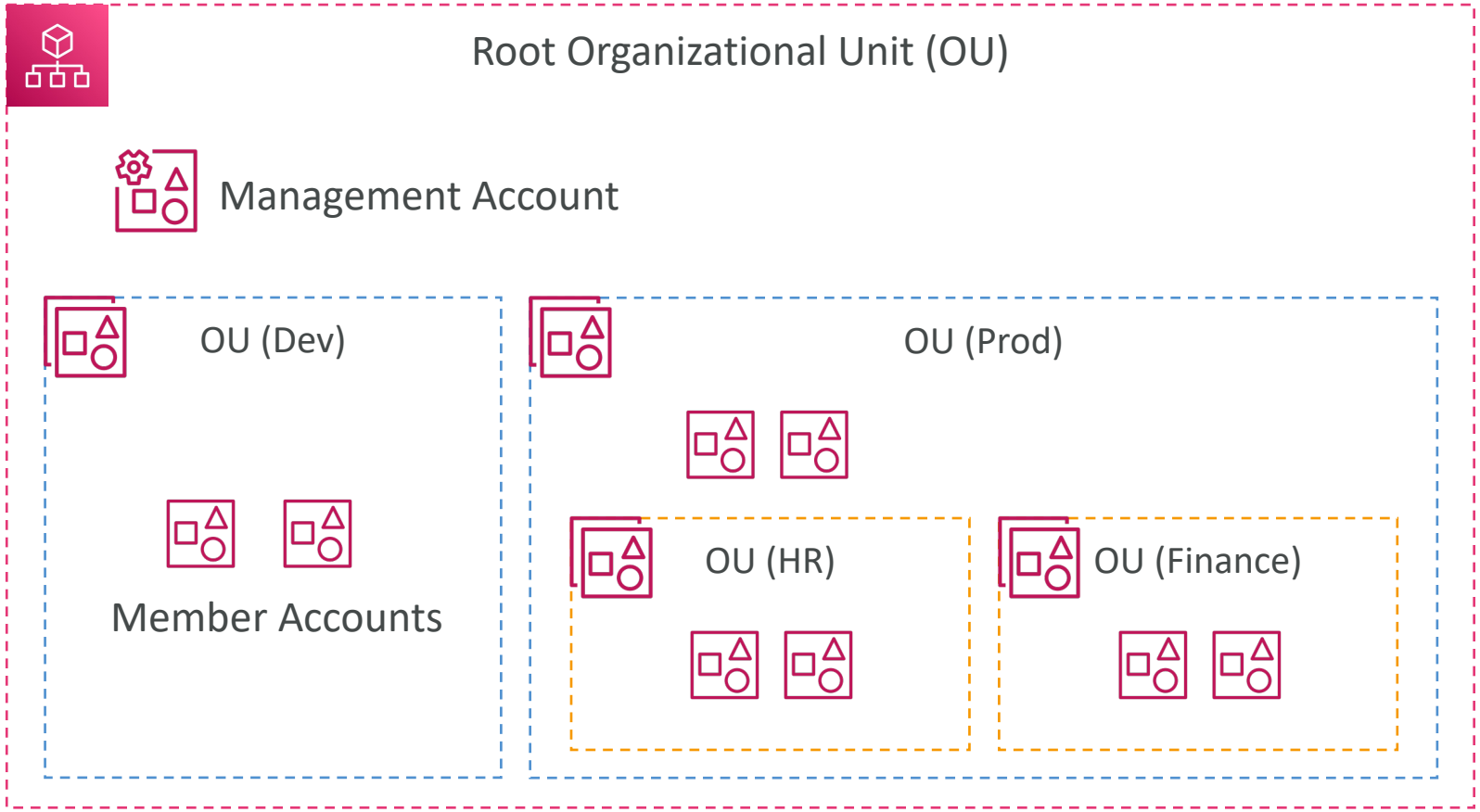


- **Simple AD** is an inexpensive Active Directory–compatible service with the common directory features.
- Supports joining EC2 instances, manage users and groups
- Does not support MFA, RDS SQL server, AWS SSO
- Small: 500 users, large: 5000 users
- Powered by Samba 4, compatible with Microsoft AD
- lower cost, low scale, basic AD compatible, or LDAP compatibility
- No trust relationship

© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

AWS Organizations

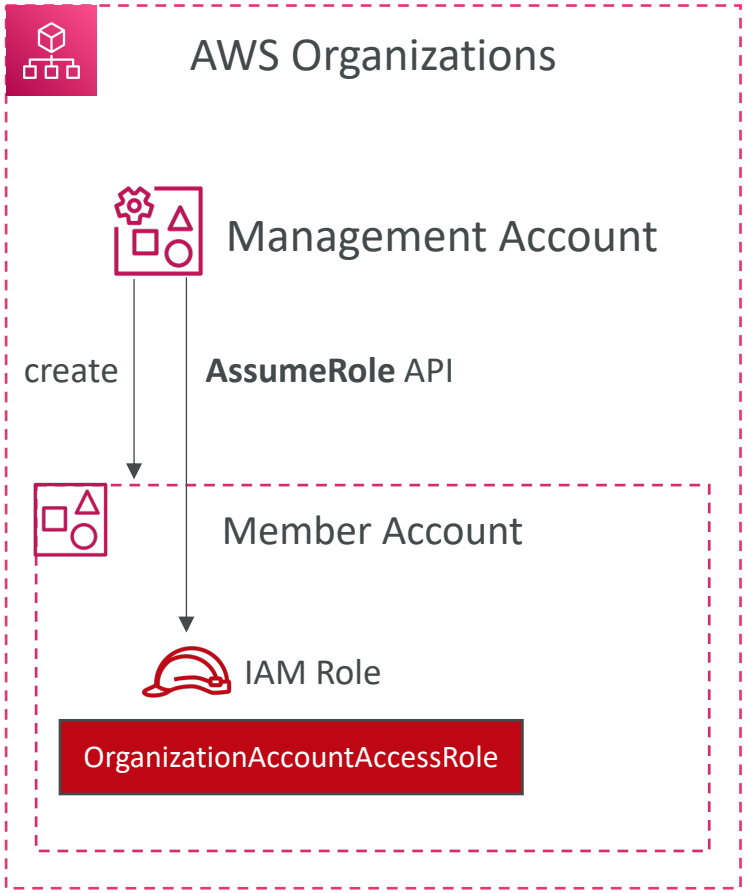


© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

AWS Organizations - OrganizationAccountAccessRole

- IAM role which grants full administrator permissions in the Member account to the Management account
- Used to perform admin tasks in the Member accounts (e.g., creating IAM users)
- Could be assumed by IAM users in the Management account
- Automatically added to all new Member accounts created with AWS Organizations
- Must be created manually if you invite an existing Member account



© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

Multi Account Strategies

- Create accounts per **department**, per **cost center,** per **dev / test / prod**, based on **regulatory restrictions** (using SCP), for **better resource isolation** (ex: VPC), to have **separate per-account service limits**, isolated account for **logging**,

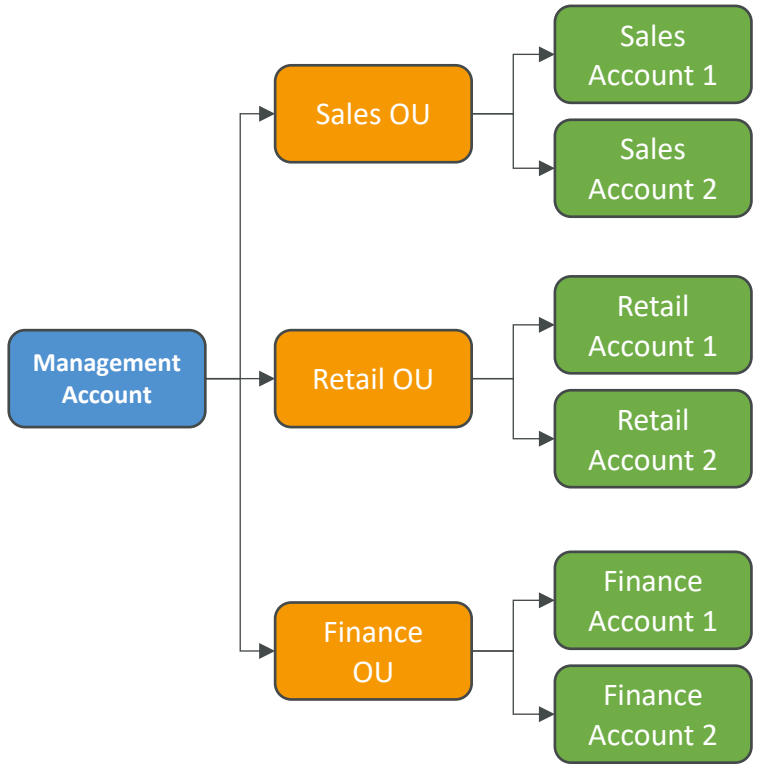
- Multi Account vs. One Account Multi VPC
- Use tagging standards for billing purposes
- Enable CloudTrail on all accounts, send logs to central S3 account
- Send CloudWatch Logs to central logging account
- Strategy to create an account for security

© Stephane Maarek

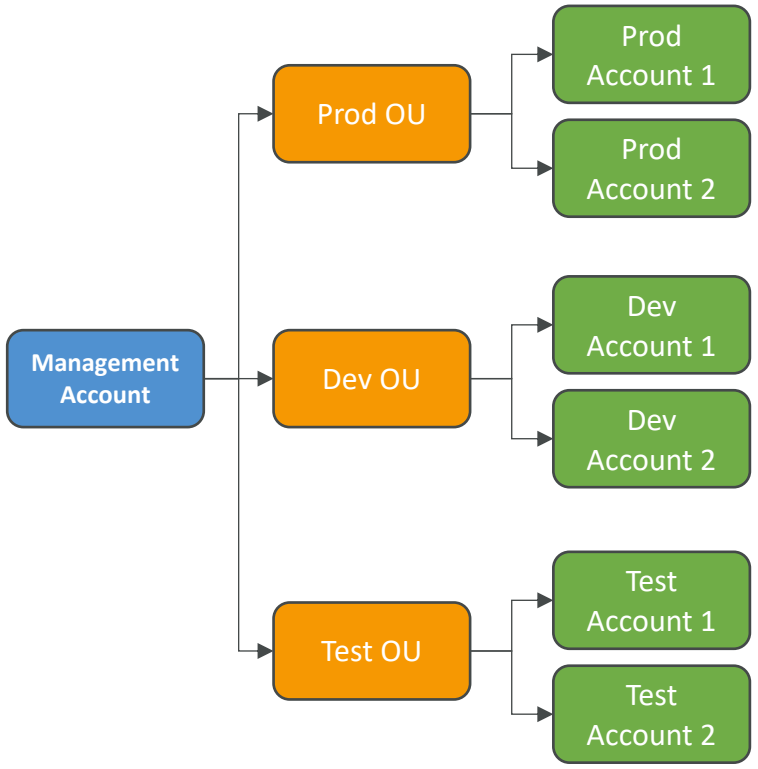
NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

Organizational Units (OU) - Examples

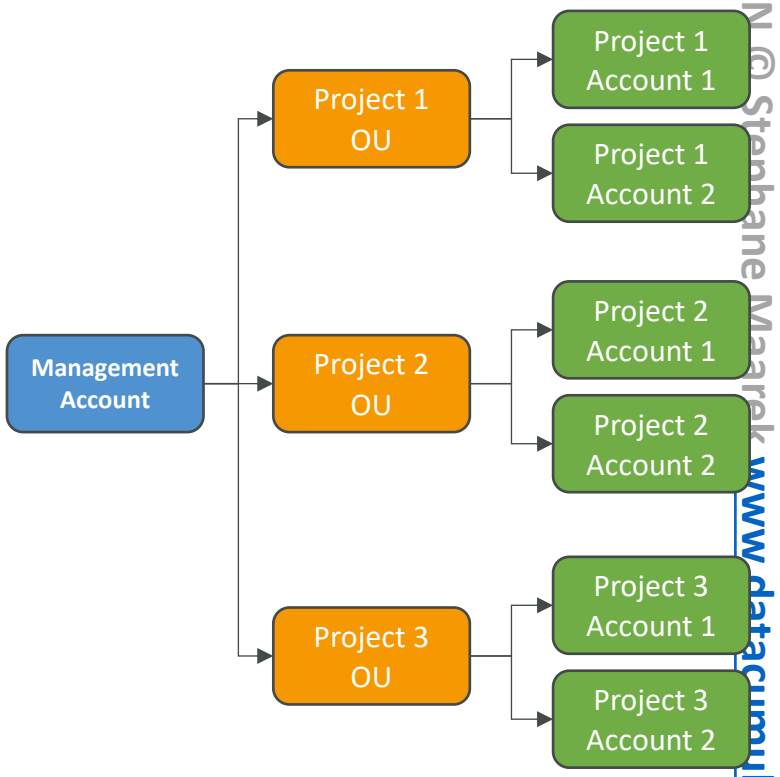
Business Unit



Environmental Lifecycle



Project-Based



© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

AWS Organization - Feature Modes

- Consolidated billing features:
  - Consolidated Billing across all accounts - single payment method
  - Pricing benefits from aggregated usage (volume discount for EC2, S3…)

- All Features (Default):
  - Includes consolidated billing features, SCP
  - Invited accounts must approve enabling all features
  - Ability to apply an SCP to prevent member accounts from leaving the org
  - Can't switch back to Consolidated Billing Features only

© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

AWS Organizations – Reserved Instances

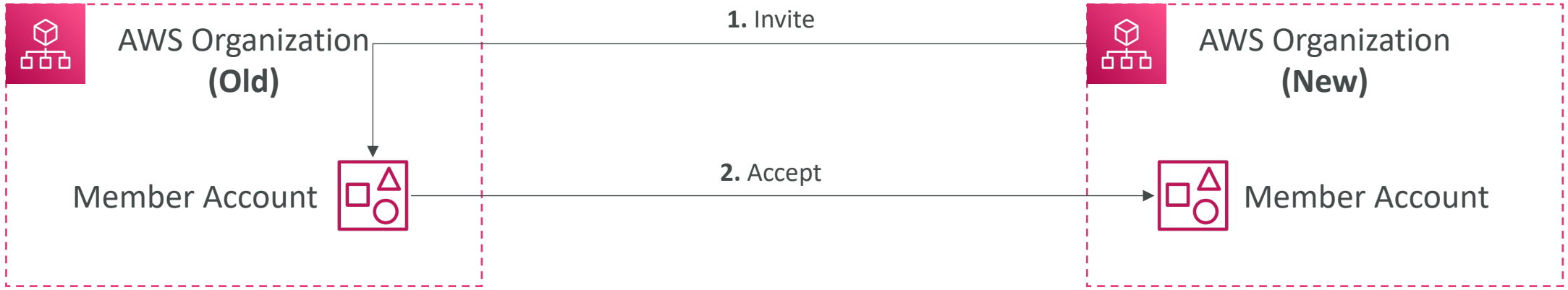
- For billing purposes, the consolidated billing feature of AWS Organizations treats all the accounts in the organization as one account.
- This means that **all accounts** in the organization can receive the hourly cost benefit of Reserved Instances that are purchased **by any other account.**
- **The payer account (Management account) of an organization** can turn off Reserved Instance (RI) discount and Savings Plans discount sharing for any accounts in that organization, including the payer account
- This means that RIs and Savings Plans discounts aren't shared between any accounts that have sharing turned off.
- To share an RI or Savings Plans discount with an account, both accounts must have sharing turned on

© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

AWS Organizations – Moving Accounts

1. Send an invite to the member account from the AWS Organization
2. Accept the invite to the new Organization from the member account



© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

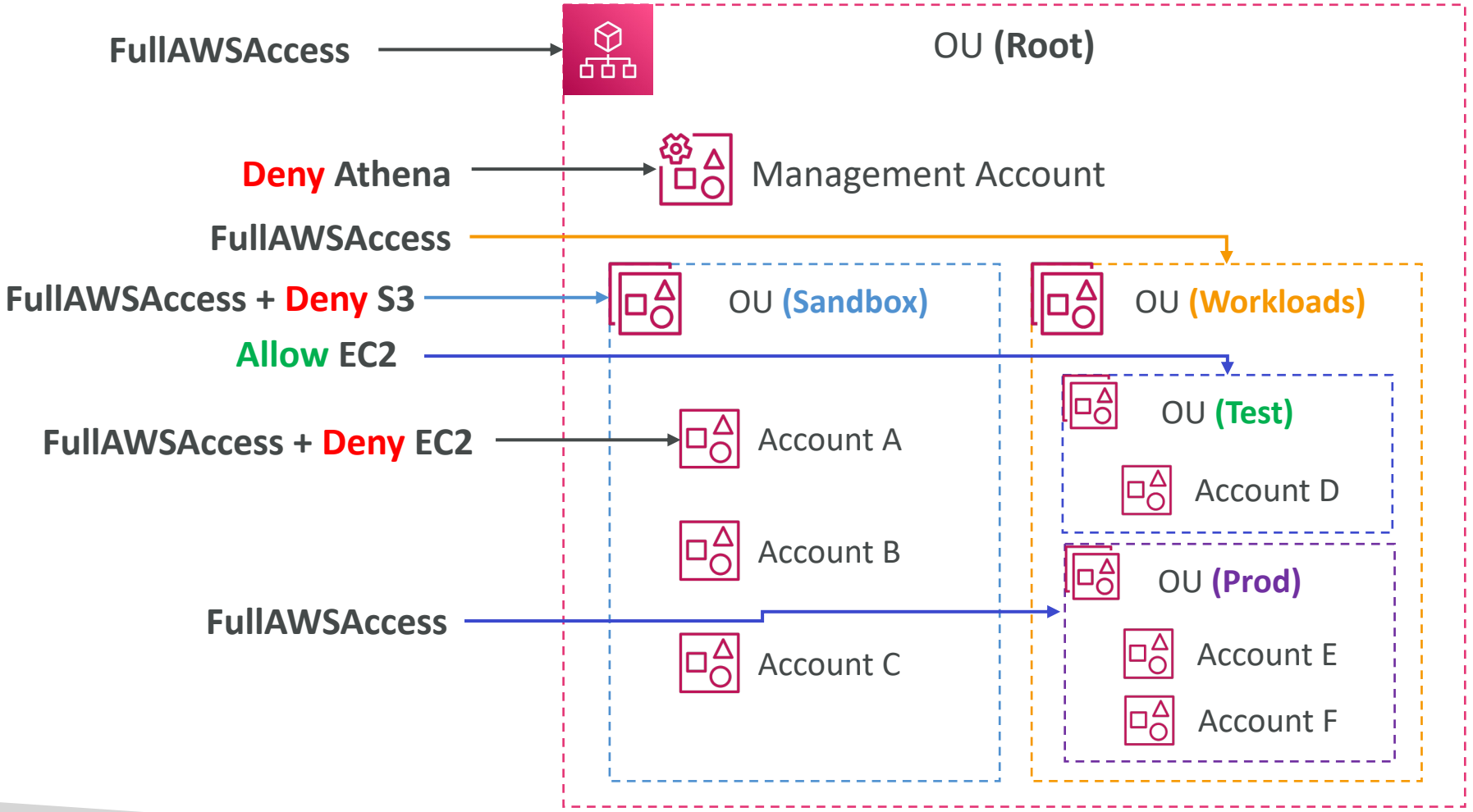
Service Control Policies (SCP)

- Define allowlist or blocklist IAM actions
- Applied at the **OU** or **Account** level
- Does not apply to the Management Account
- SCP is applied to all the **Users and Roles** in the account, including Root user
- The SCP does not affect Service-linked roles
  - Service-linked roles enable other AWS services to integrate with AWS Organizations and can't be restricted by SCPs.
- SCP must have an explicit Allow from the root a each OU in the direct path to the target account (does not allow anything by default)
- Use cases:
  - Restrict access to certain services (for example: can't use EMR)
  - Enforce PCI compliance by explicitly disabling services

© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

SCP Hierarchy



- Management Account
  - Can do anything (no SCP apply)
- Account A
  - Can do anything
  - EXCEPT S3 (explicit Deny from Sandbox OU)
  - EXCEPT EC2 (explicit Deny)
- Account B & C
  - Can do anything
  - EXCEPT S3 (explicit Deny from Sandbox OU)
- Account D
  - Can access EC2
- Prod OU & Account E & F
  - Can do anything

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

© Stephane Maarek

SCP Examples
Blocklist and Allowlist strategies

```
{
    "Version": "2012-10-17",
    "Statement": [
        {
            "Sid": "AllowsAllActions",
            "Effect": "Allow",
            "Action": "*",
            "Resource": "*"
        },
        {
            "Sid": "DenyDynamoDB",
            "Effect": "Deny",
            "Action": "dynamodb:*",
            "Resource": "*"
        }
    ]
}
```

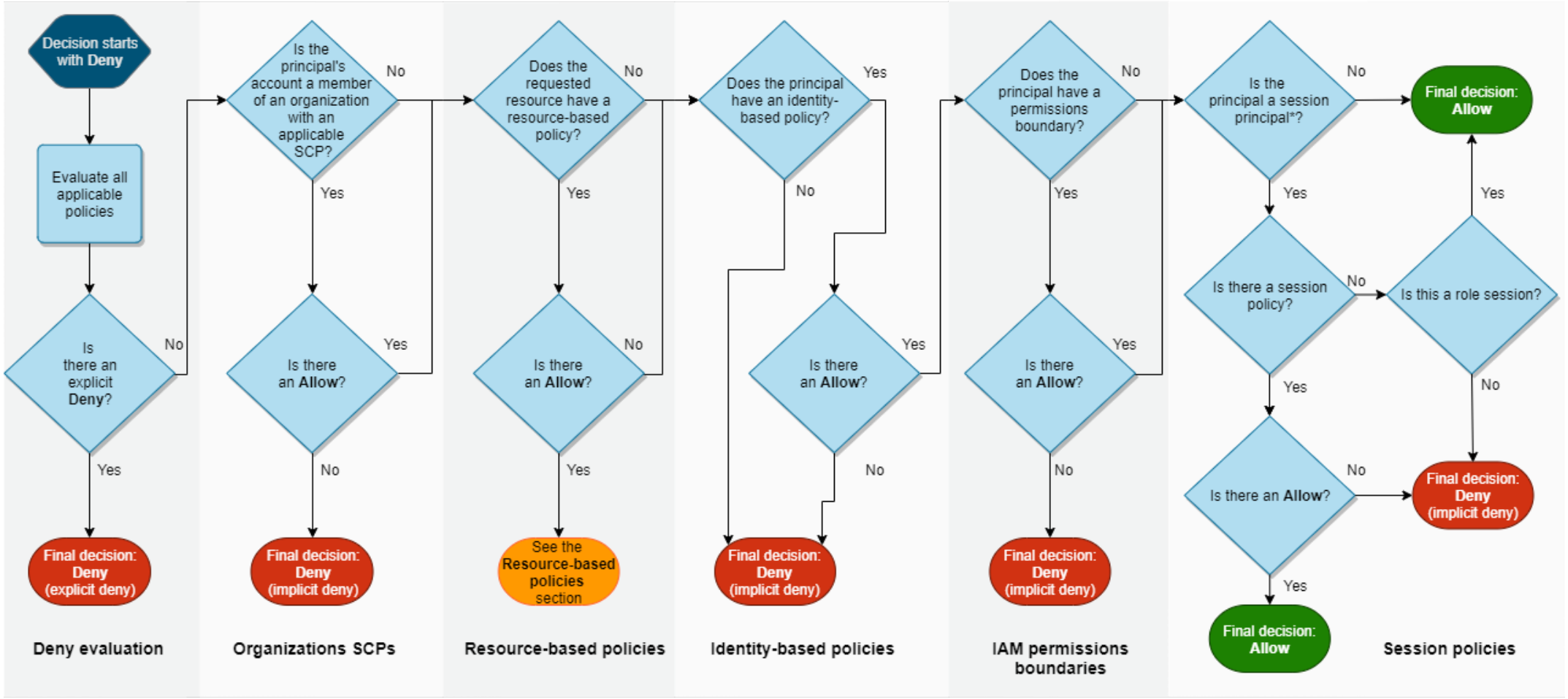
```
{
    "Version": "2012-10-17",
    "Statement": [
        {
            "Effect": "Allow",
            "Action": [
                "ec2:*",
                "cloudwatch:*"
            ],
            "Resource": "*"
        }
    ]
}
```

More examples: https://docs.aws.amazon.com/organizations/latest/userguide/orgs_manage_policies_example-scps.html

© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

IAM Policy Evaluation Logic



*A session principal is either a role session or an IAM federated user session.

https://docs.aws.amazon.com/IAM/latest/UserGuide/reference_policies_evaluation-logic.html

© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

Restricting Tags with IAM Policies

- You can restrict specific Tags on AWS resources
- Using the **aws:TagKeys** Condition Key
  - Validate the Tag Keys attached to a resource against the Tag Keys in the IAM Policy
- Example: allow IAM users to create EBS Volumes only if it has the "Env" and "CostCenter" Tags
- Use either **ForAllValues** (must have all keys) or **ForAnyValue** (must have any of these keys at a minimum)

```
{
    "Version": "2012-10-17",
    "Statement": [
        {
            "Effect": "Allow",
            "Action": "ec2:CreateVolume",
            "Resource": "arn:aws:ec2:*:*:volume/*",
            "Condition": {
                "ForAllValues:StringEquals": {
                    "aws:TagKeys": ["Env", "CostCenter"]
                }
            }
        }
    ]
}
```

Match **All** Keys

```
{
    "Version": "2012-10-17",
    "Statement": [
        {
            "Effect": "Allow",
            "Action": "ec2:CreateVolume",
            "Resource": "arn:aws:ec2:*:*:volume/*",
            "Condition": {
                "ForAnyValue:StringEquals": {
                    "aws:TagKeys": ["Env", "CostCenter"]
                }
            }
        }
    ]
}
```

Match **Any** Keys

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

© Stephane Maarek

Using SCP to Deny a Region aws:RequestedRegion

```
{
    "Version": "2012-10-17",
    "Statement": [
        {
            "Effect": "Deny",
            "Action": ["ec2:*", "rds:*", "dynamodb:*"],
            "Resource": "*",
            "Condition": {
                "StringEquals": {
                    "aws:RequestedRegion": ["eu-central-1", "eu-west-1"]
                },
                "ArnNotLike": {
                    "aws:PrincipalARN": [
                        "arn:aws:iam::*:role/Role1AllowedToBypassThisSCP",
                        "arn:aws:iam::*:role/Role2AllowedToBypassThisSCP"
                    ]
                }
            }
        }
    ]
}
```

© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

Using SCP to Restrict Creating Resources without appropriate Tags

- Prevent IAM Users/Roles in the affected Member accounts from creating resources if they don't have a specific Tags

- Example: restrict launching an EC2 instance if it doesn't have the "Project" and "CostCenter" Tags

```
{
    "Version": "2012-10-17",
    "Statement": [
        {
            "Sid": "DenyRunInstanceWithNoProjectTag",
            "Effect": "Deny",
            "Action": "ec2:RunInstances",
            "Resource": ["arn:aws:ec2:*:*:instance/*", "arn:aws:ec2:*:*:volume/*"],
            "Condition": {
                "Null": {
                    "aws:RequestTag/Project": "true"
                }
            }
        },
        {
            "Sid": "DenyRunInstanceWithNoCostCenterTag",
            "Effect": "Deny",
            "Action": "ec2:RunInstances",
            "Resource": ["arn:aws:ec2:*:*:instance/*", "arn:aws:ec2:*:*:volume/*"],
            "Condition": {
                "Null": {
                    "aws:RequestTag/CostCenter": "true"
                }
            }
        }
    ]
}
```

© Stephane Maarek

NOT FOR DISTRIBUTION

AWS Organizations – Tag Policies

- Helps you standardize tags across resources in an AWS Organization
- Ensure consistent tags, audit tagged resources, maintain proper resources categorization, …
- You define Tag keys and their allowed values
- Helps with AWS Cost Allocation Tags and Attribute-based Access Control
- Prevent any non-compliant tagging operations on specified services and resources
- Generate a report that lists all tagged/non-compliant resources
- Use Amazon EventBridge to monitor non-compliant tags

```
{
    "tags": {
        "costcenter": {
            "tag_key": {
                "@@assign": "CostCenter"
            },
            "tag_value": {
                "@@assign": ["100", "200"]
            },
            "enforced_for": {
                "@@assign": ["secretsmanager:*"]
            }
        }
    }
}
```

© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

AWS Organizations – AI Services Opt-out Policies

- Certain AWS AI services may use your content for continuous improvement of Amazon AI/ML services
- Example: Amazon Lex, Amazon Comprehend, Amazon Polly, …

- You can opt-out of having your content stored or used by AWS AI services
- Create an Opt-out Policy that enforces this setting across all Member accounts and AWS Regions
- You can opt-out all AI services or selected services
- Can be attached to Organization Root, specific OU, or individual Member account

```
{
    "services": {
        "default": {
            "opt_out_policy": {
                "@@assign": "optOut"
            }
        }
    }
}
```

All Services

```
{
    "services": {
        "rekognition": {
            "opt_out_policy": {
                "@@assign": "optOut"
            }
        },
        "lex": {
            "opt_out_policy": {
                "@@assign": "optOut"
            }
        }
    }
}
```

ONLY Rekognition & Lex

© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

AWS Organizations – Backup Policies

- AWS Backup enables you to create Backup Plans that define how to backup your AWS resources

- JSON documents that define Backup Plans across an AWS Organization
- Gives you granular control over backing up your resources (e.g., backup frequency, time window, backup region, …)
- Can be attached to Organization Root, specific OU, or individual Member account
- **Immutable** Backup Plans appear in Member accounts (view ONLY)

```
{
    "plans": {
        "PII_Backup_Plan": {
            "regions": {
                "@@assign": ["us-east-1"]
            },
            "rules": {
                "My_Hourly_Rule": {
                    "schedule_expression": { "@@assign": "cron(0 5 ? * * *)" },
                    "start_backup_window_minutes": { "@@assign": "60" },
                    "complete_backup_window_minutes": { "@@assign": "604800" },
                    "enable_continuous_backup": { "@@assign": false },
                    "target_backup_vault_name": { "@@assign": "My_Backup_Vault" },
                    "lifecycle": {
                        "move_to_cold_storage_after_days": { "@@assign": "180" },
                        "delete_after_days": { "@@assign": "270" }
                    }
                }
            }
        }
    }
}
```

© Stephane Maarek

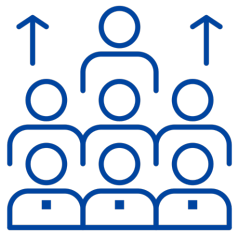
NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

AWS IAM Identity Center (successor to AWS Single Sign-On)



- One login (single sign-on) for all your
  - **AWS accounts in AWS Organizations**
  - Business cloud applications (e.g., Salesforce, Box, Microsoft 365, …)
  - SAML2.0-enabled applications
  - EC2 Windows Instances

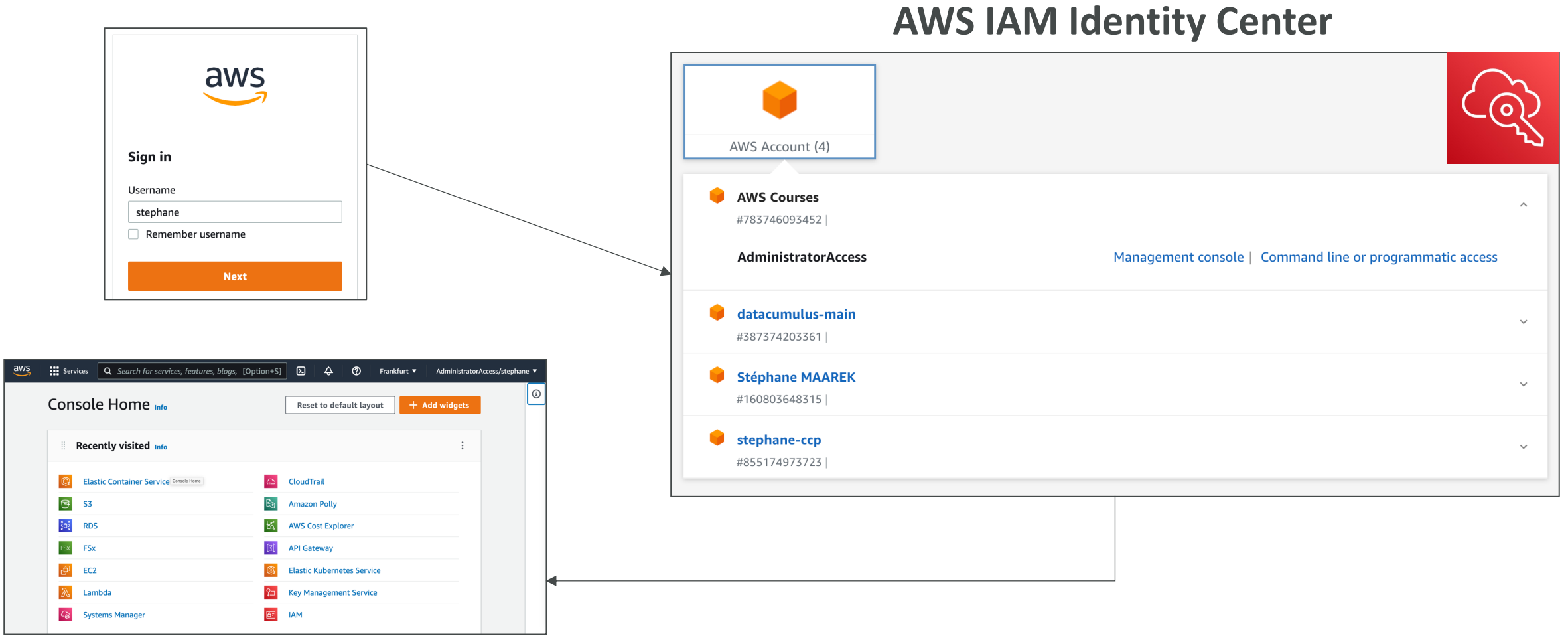
- Identity providers
  - Built-in identity store in IAM Identity Center
  - 3rd party: Active Directory (AD), OneLogin, Okta…



© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

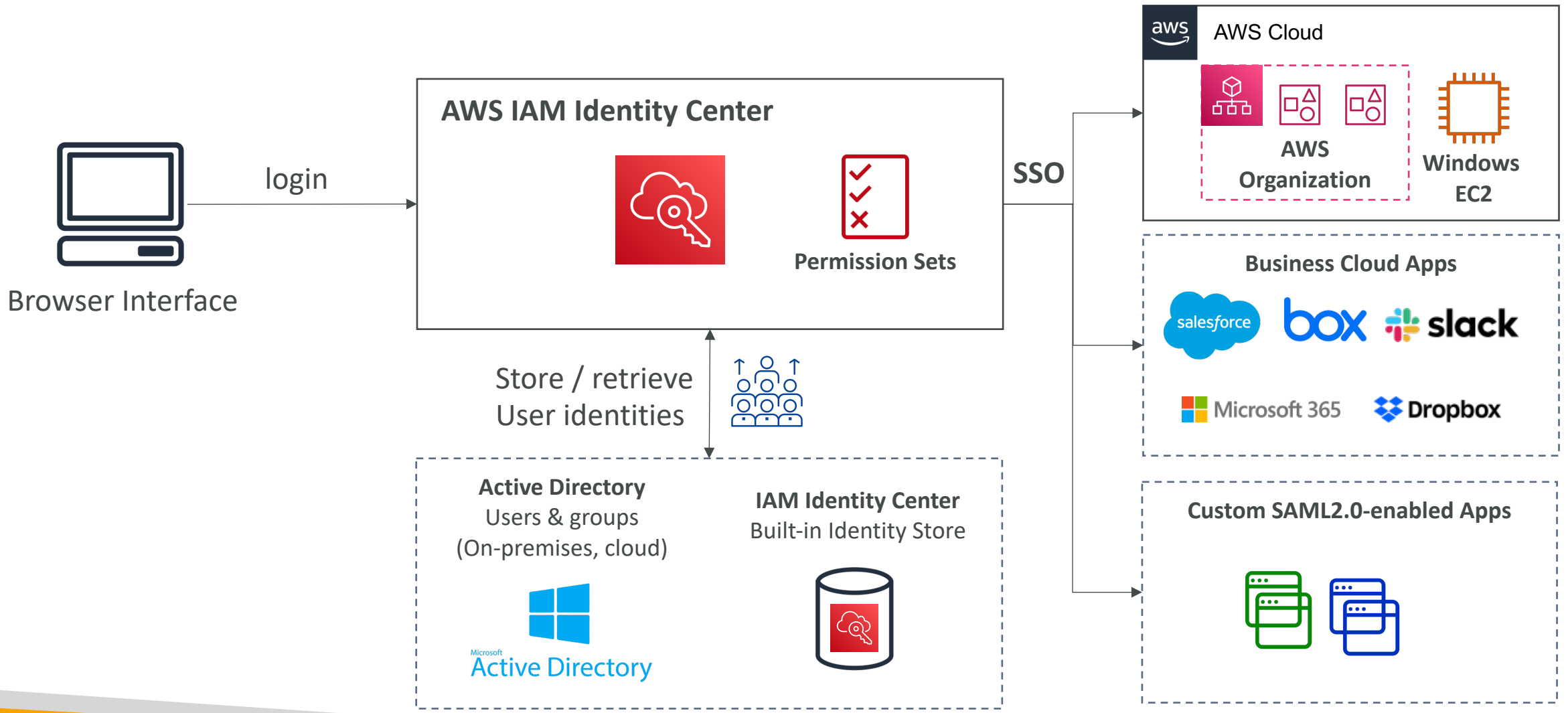
AWS IAM Identity Center – Login Flow



© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

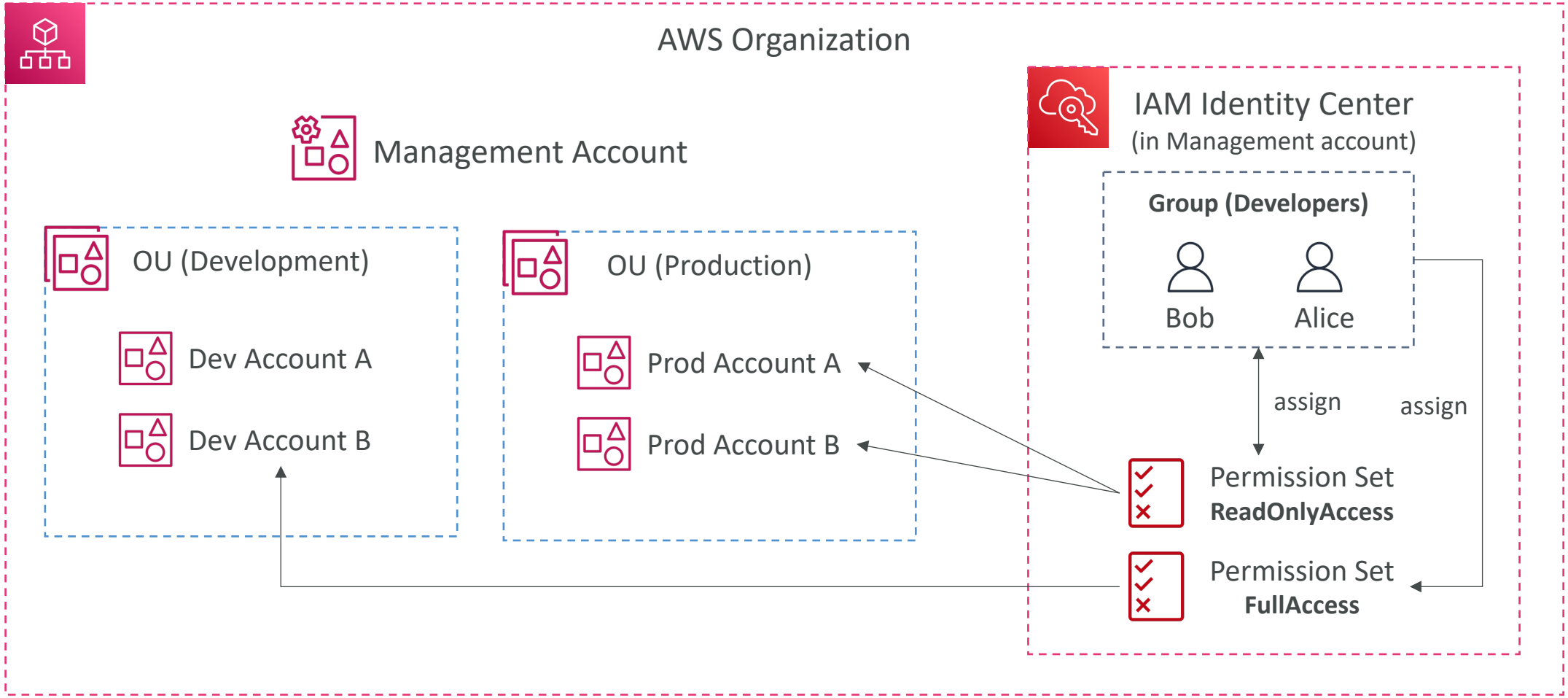
AWS IAM Identity Center



© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

IAM Identity Center

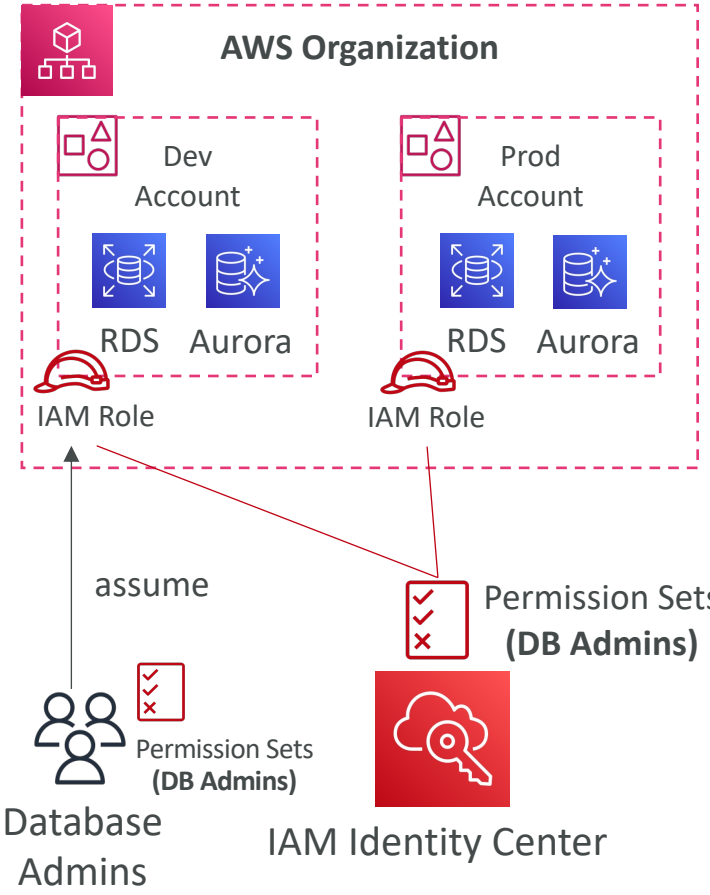


© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

AWS IAM Identity Center
Fine-grained Permissions and Assignments

- Multi-Account Permissions
  - Manage access across AWS accounts in your AWS Organization
  - Permission Sets – a collection of one or more IAM Policies assigned to users and groups to define AWS access
- Application Assignments
  - SSO access to many SAML 2.0 business applications (Salesforce, Box, Microsoft 365, …)
  - Provide required URLs, certificates, and metadata
- Attribute-Based Access Control (ABAC)
  - Fine-grained permissions based on users' attributes stored in IAM Identity Center Identity Store
  - Example: cost center, title, locale, …
  - Use case: Define permissions once, then modify AWS access by changing the attributes



© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

AWS Control Tower



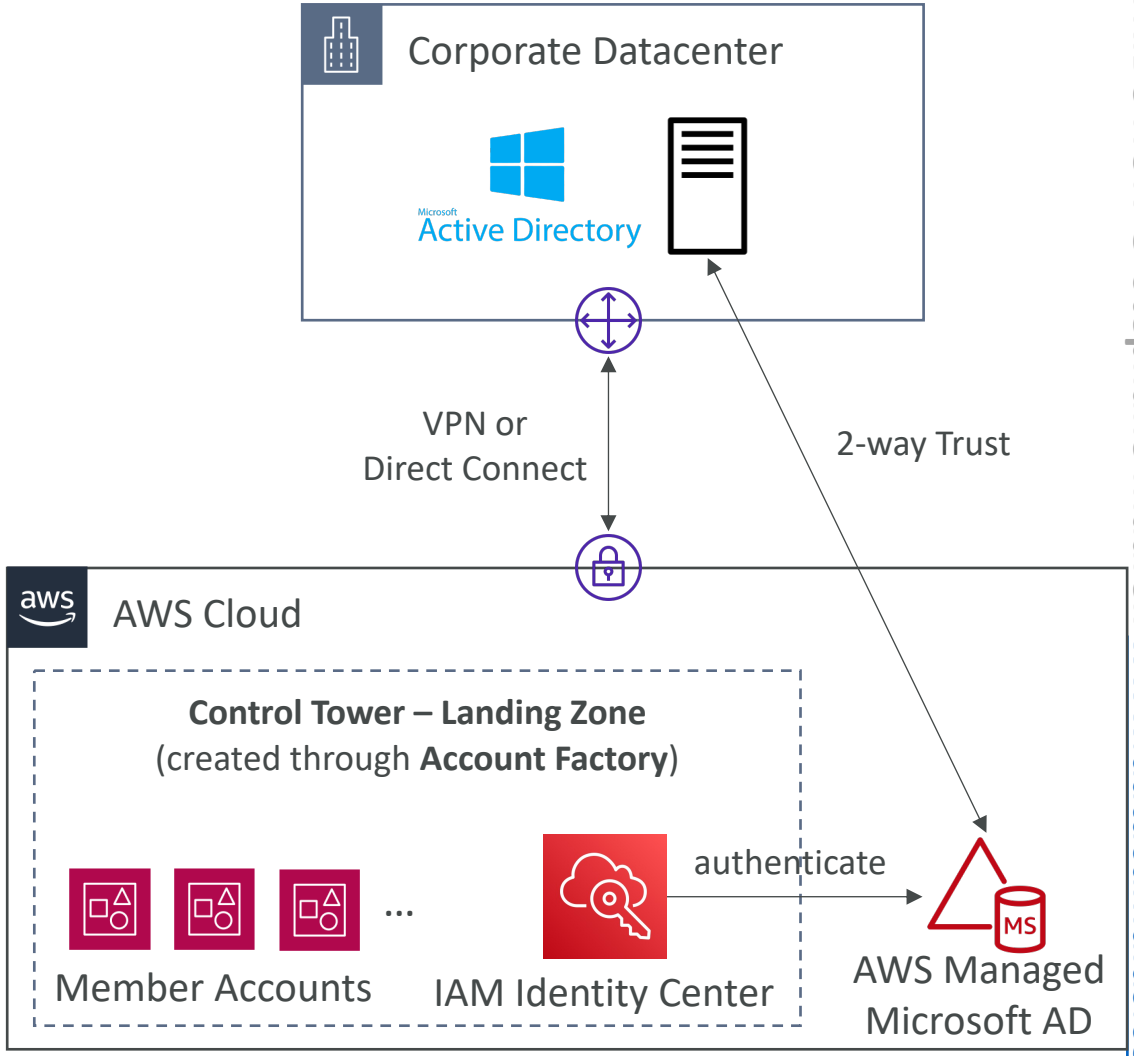
- Easy way to **set up and govern a secure and compliant multi-account AWS environment** based on best practices
- Benefits:
  - Automate the set up of your environment in a few clicks
  - Automate ongoing policy management using guardrails
  - Detect policy violations and remediate them
  - Monitor compliance through an interactive dashboard
- AWS Control Tower runs on top of AWS Organizations:
  - It automatically sets up AWS Organizations to organize accounts and implement SCPs (Service Control Policies)

© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

AWS Control Tower – Account Factory

- Automates account provisioning and deployments
- Enables you to create pre-approved baselines and configuration options for AWS accounts in your organization (e.g., VPC default configuration, subnets, region, …)
- Uses AWS Service Catalog to provision new AWS accounts

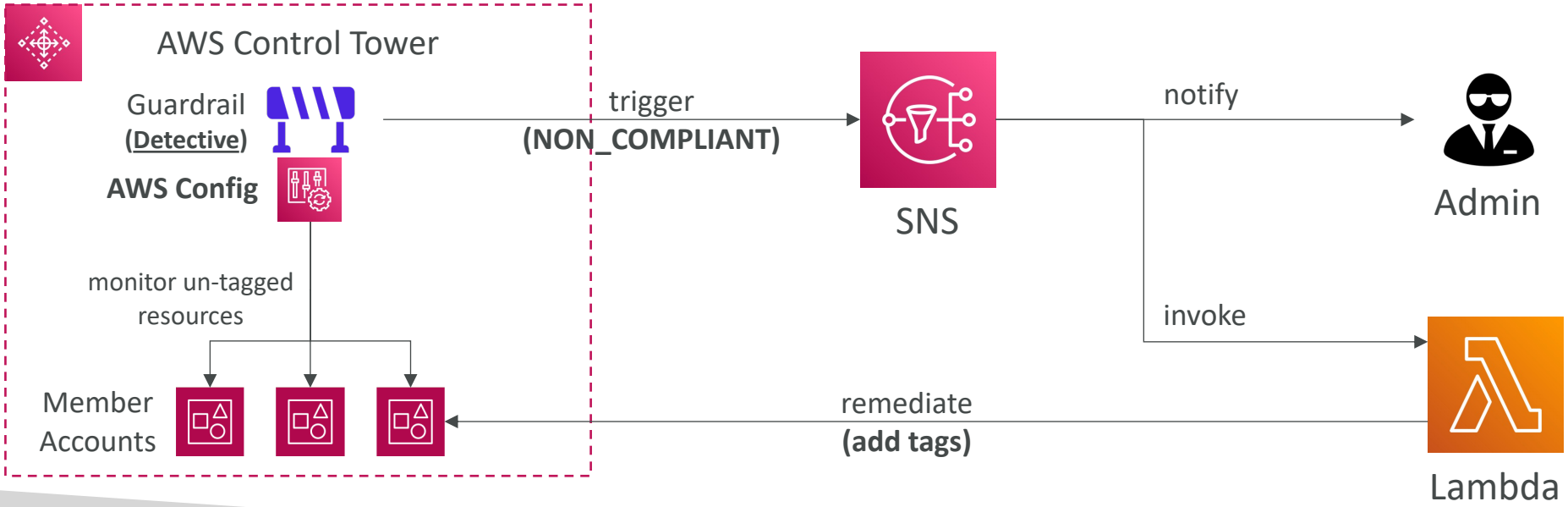


© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

AWS Control Tower – Detect and Remediate Policy Violations

- Guardrail
  - Provides ongoing governance for your Control Tower environment (AWS Accounts)
  - **Preventive – using SCPs** (e.g., Disallow Creation of Access Keys for the Root User)
  - **Detective – using AWS Config** (e.g., Detect Whether MFA for the Root User is Enabled)
  - Example: identify non-compliant resources (e.g., untagged resources)



© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

AWS Control Tower – Guardrails Levels

- Mandatory
  - Automatically enabled and enforced by AWS Control Tower
  - Example: Disallow public Read access to the Log Archive account
- Strongly Recommended
  - Based on AWS best practices (optional)
  - Example: Enable encryption for EBS volumes attached to EC2 instances
- Elective
  - Commonly used by enterprises (optional)
  - Example: Disallow delete actions without MFA in S3 buckets

© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

AWS Resource Access Manager (RAM)

- Share AWS resources that you own with other AWS accounts
- Share with any account or within your Organization
- Avoid resource duplication!
- VPC Subnets
  - Allow to have all the resources launched in the same subnets
  - Must be from the same AWS Organizations.
  - Cannot share default security groups and default VPC
  - Participants can manage their own resources in there
  - Participants can't view, modify, delete resources that belong to other participants or the owner
- AWS Transit Gateway
- Route 53 (Resolver Rules, DNS Firewall Rule Groups)
- License Manager Configurations

© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

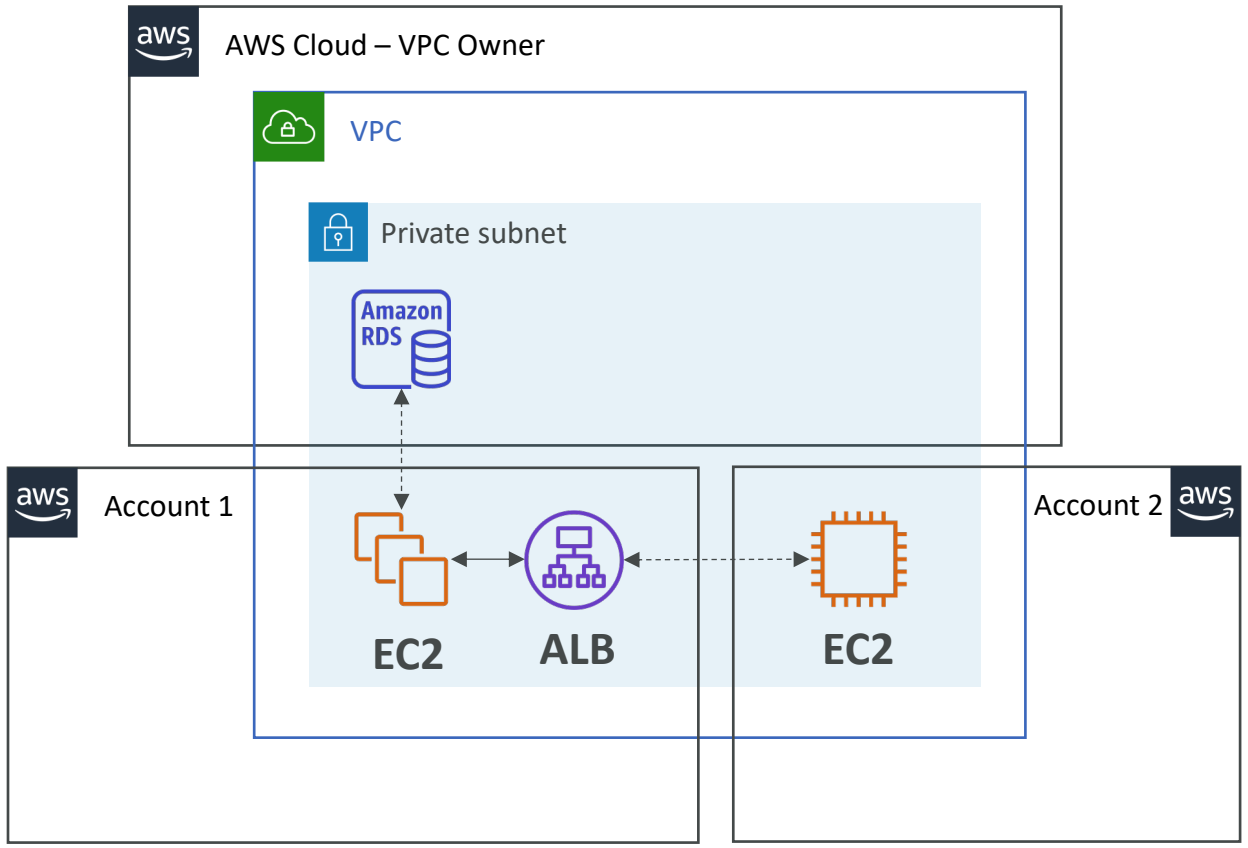
AWS Resource Access Manager (RAM)

- Aurora DB Clusters
- ACM Private Certificate Authority
- CodeBuild Project
- EC2 (Dedicated Hosts, Capacity Reservation)
- AWS Glue (Catalog, Database, Table)
- AWS Network Firewall Policies
- AWS Resource Groups
- Systems Manager Incident Manager (Contacts, Response Plans)
- AWS Outposts (Outpost, Site)

© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

Resource Access Manager – VPC example



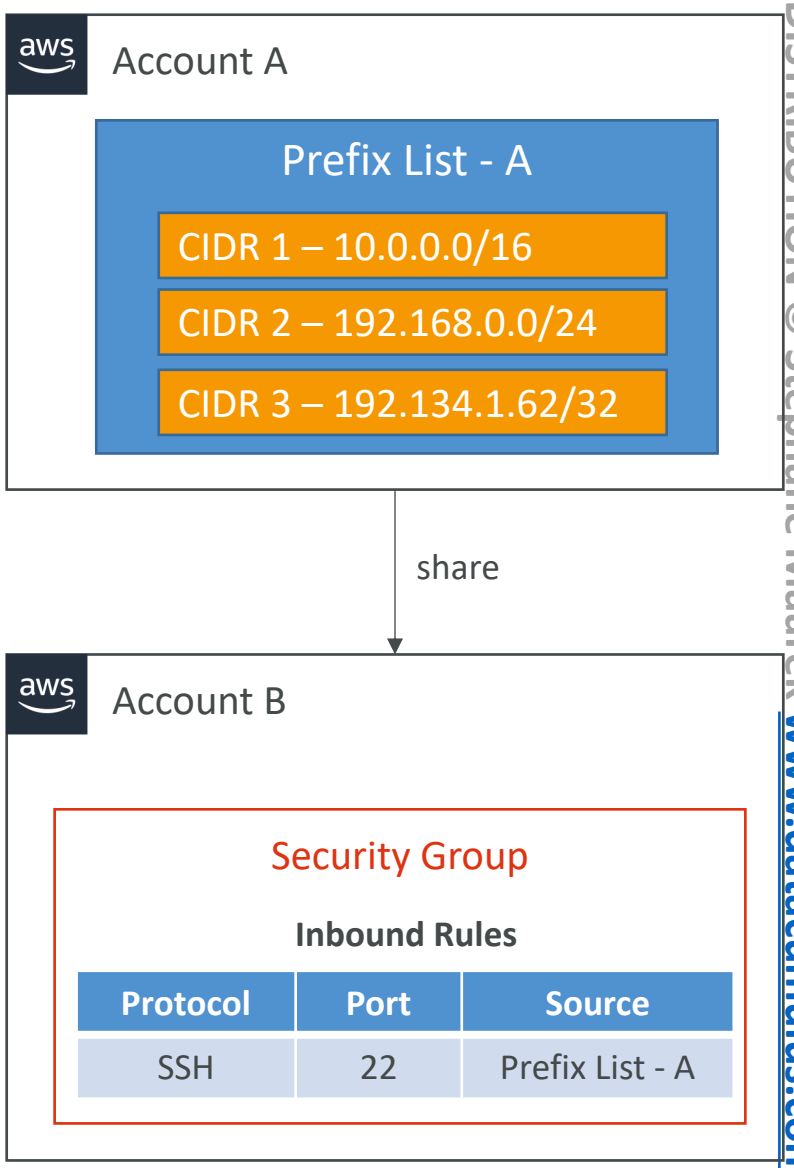
- Each account…
  - is responsible for its own resources
  - cannot view, modify or delete other resources in other accounts
- Network is shared so…
  - Anything deployed in the VPC can talk to other resources in the VPC
  - Applications are accessed easily across accounts, using private IP!
  - Security groups from other accounts can be referenced for maximum security
- Use cases
  - Applications within the same trust boundaries
  - Applications with a high degree of interconnectivity

© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

Resource Access Manager Managed Prefix List

- A set of one or more CIDR blocks
- Makes it easier to configure and maintain Security Groups and Route Tables
- Customer-Managed Prefix List
  - Set of CIDRs that you define and manage by you
  - Can be shared with other AWS accounts or AWS Organization
  - Modify to update many security groups at once
- AWS-Managed Prefix List
  - Set of CIDRs for AWS services
  - You can't create, modify, share, or delete them

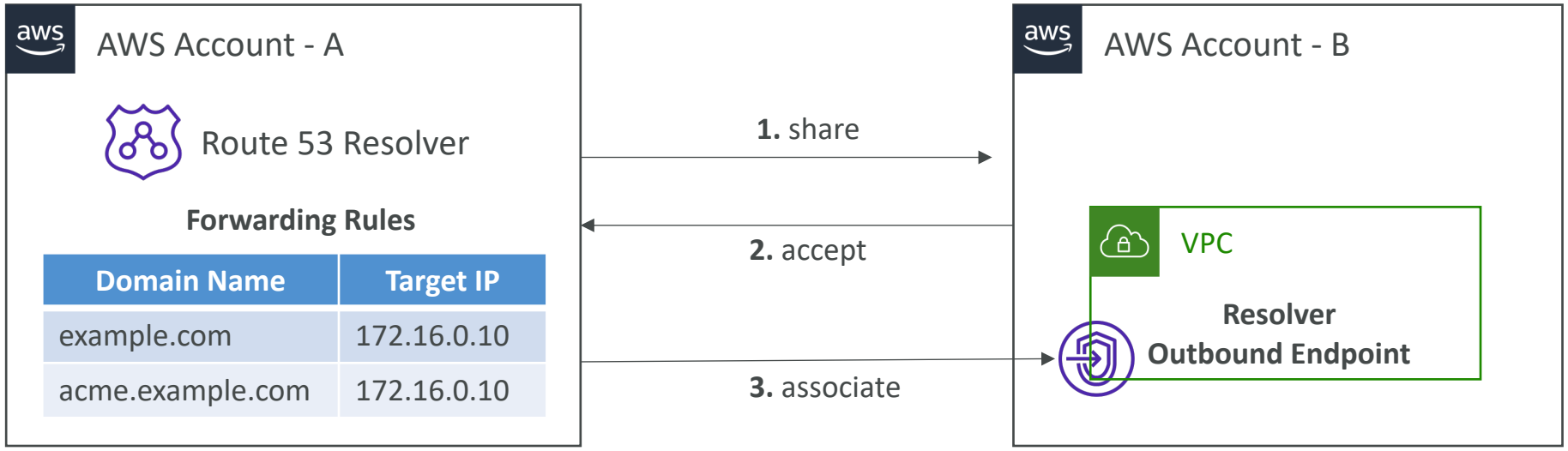


© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

Resource Access Manager
Route 53 Outbound Resolver

- Helps you scale forwarding rules to your DNS in case you have multiple accounts and VPC



© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com

Summary of Identity & Federation

- Users and Accounts all in AWS
- AWS Organizations
- AWS Control Tower to setup secure & complaint multi-account AWS environment (best practices)
- Federation with SAML
- Federation without SAML with a custom IdP (**GetFederationToken**)
- IAM Identity Center to connect to multiple AWS Accounts (Organization) and SAML apps
- Web Identity Federation (not recommended)
- Cognito for most web and mobile applications (has anonymous mode, MFA)
- AWS Directory Service:
  - **Managed Microsoft AD** – standalone or setup trust AD with on-premises, has MFA, seamless join, RDS integration
  - **AD Connector** – proxy requests to on-premises
  - **Simple AD** – standalone & cheap AD-compatible with no MFA, no advanced capabilities
- AWS RAM to share resources (example VPC subnets)

© Stephane Maarek

NOT FOR DISTRIBUTION © Stephane Maarek www.datacumulus.com